

Sri Lanka Institute of Information Technology



IE3101 – Enterprise Network and Information systems security

Network Security Assessment and Secure Network Design

Prismo Constructions (PVT) Ltd

Digital Transformation Platform for Construction Consultancy

ISE_WE_0201_49

Year 3, Semester 1

Student ID	Name
IT24103929	Wijerathne W.A.D.C. L
IT24103951	Rathnayaka R.M.D. D
IT24103657	Sathsarani W.A.N. P
IT24201063	Sandothma H.B. D

Prof. Anuradha Jayakody

2026/10/02

Declaration

We declare that this project Network Security Assessment and Secure Network Design report or part of it was not a copy of a document done by any organization, university or any other institute or a previous student project group at SLIIT and was not copied from the Internet or other sources.

Project Details

Project Title	Digital Transformation Platform for Construction Consultancy – Prismo Constructions
Project ID	ISE_WE_0201_49

Group Members

Student ID	Name
IT24103929	Wijerathne W.A.D.C.L
IT24103951	Rathnayaka R.M.D.D
IT24103657	Sathsarani W.A.N.P
IT24201063	Sandothma H.B.D

Contents

1. Client and Network Environment Analysis	6
1.1 Introduction.....	6
1.2 Client Organization Profile	7
1.3 Business Context and Digital Transformation Need.....	9
1.4 Current IT and Network Environment (As-Is).....	10
1.5 Planned New System – Prismo Constructions Overview	12
1.6 Scope of the New / Expanded Network	14
1.7 Stakeholders Related to Network and Security.....	15
1.8 Assumptions.....	16
1.9 Summary of Step 1.....	18
2. Network Architecture Analysis / Proposed Network Design	19
2.1 Introduction.....	19
2.2 Network Requirements Analysis	19
2.3 High-Level Network Design Principles.....	20
2.4 Proposed Logical Network Architecture.....	21
2.5 Key Network Components.....	22
2.6 Access Control and Connectivity.....	24
2.7 Network Diagram.....	25
2.8 Justification of the Proposed Design.....	26
2.9 Summary of Task 2.....	27
3. Initial Security and Vulnerability Identification	28
3.1 Introduction.....	28
3.2 Asset Identification (High-Level)	28
3.3 Threat Landscape Overview	30
3.4 Identified Vulnerabilities	31
3.4.1 Network and Infrastructure Vulnerabilities	31
3.4.2 Access Control and Authentication Vulnerabilities	32
3.4.3 Data and Application Vulnerabilities.....	33
3.4.4 Human and Process Vulnerabilities	33
3.4.5 Physical and Endpoint Vulnerabilities	34
3.5 Vulnerability Summary Table.....	35
3.6 Impact of Identified Vulnerabilities.....	37
3.7 Summary of Task 3	38
4. Vulnerability and Risk Assessment	39

4.1 Introduction.....	39
4.2 Risk Assessment Methodology	39
4.3 Risk Assessment Criteria	41
4.4 Detailed Risk Assessment.....	42
4.5 Risk Summary by Level.....	44
4.6 Key Risk Insights	46
4.7 Summary of Task 4	47
5. ISO/IEC 27001 Alignment and Risk Treatment	48
5.1 Introduction.....	48
5.2 Overview of ISO/IEC 27001 Relevance	48
5.3 Information Asset Register and Valuation	49
5.4 Risk Register (ISO 27001 Aligned)	50
5.5 Control Selection and Gap Analysis	51
5.6 Statement of Applicability (High-Level)	53
5.7 Risk Treatment Plan.....	54
5.8 Roles and Responsibilities	56
5.9 Summary of Task 5	58
6. Secure Network Architecture (To-Be Design).....	59
6.1 Introduction.....	59
6.2 Design Objectives and Security Goals.....	59
6.3 Design Principles Applied	60
6.4 Proposed To-Be Secure Network Architecture Overview	61
6.5 Detailed Network Zones and Components	61
6.5.1 Office User Zone.....	61
6.5.2 Server / Application Zone	62
6.5.3 Remote Access Zone.....	62
6.5.4 External / Client Access Path.....	62
6.5.5 Management / Security Zone	63
6.6 Security Controls Integrated into the Architecture	64
6.7 Mapping of Controls to Identified Risks.....	65
6.8 To-Be Secure Network Diagram.....	66
6.9 Scalability and Future Considerations	67
6.10 Summary of Task 6	68
7. Recommendations and Implementation Priorities	69
7.1 Introduction.....	69

7.2 Recommendation Approach and Prioritization Criteria.....	69
7.3 Prioritized Security Recommendations.....	70
7.4 Detailed Recommendation Table.....	72
7.5 Implementation Considerations	74
7.6 Residual Risk Overview	75
7.8 Summary of Task 7.....	76
8. Conclusion	77
9. References.....	78
Appendices.....	79
Appendix A – Information Asset Register.....	79
Appendix B – Information Classification Matrix	80
Appendix C – Risk Register	80
Appendix D – Statement of Applicability (SoA).....	81
Appendix E – Simplified RASCI Table.....	82
Appendix F – Glossary of Key Terms	82

1. Client and Network Environment Analysis

1.1 Introduction

This section presents a detailed analysis of the client organization and its network environment as the foundation for the Enterprise Network and Information System Security assessment. The primary purpose of this analysis is to establish a clear and accurate understanding of Prismo Constructions (PVT) Ltd current business operations, existing information technology infrastructure, and the requirements arising from their planned digital transformation. By thoroughly examining the organizational context, operational challenges, and the proposed Prismo Constructions system, this section provides the necessary baseline for identifying security vulnerabilities, assessing risks, and designing a secure and scalable network architecture in the subsequent stages of this report.

Prismo Constructions (PVT) Ltd is a Sri Lankan construction consultancy firm that is currently expanding its service portfolio into full construction project management. At present, the organization largely relies on manual processes such as email communication, WhatsApp messaging, phone calls, and paper-based documentation to manage client interactions and project-related activities. With the appointment of new staff members, including Project Managers and Site Engineers, and the intention to handle complete construction projects, the organization has recognized the need for a structured digital platform. To address this need, the company plans to implement Prismo Constructions, a web-based project management system designed to support project creation, task assignment, site progress tracking, document sharing, and client approvals.

Given that Prismo Constructions (PVT) Ltd is introducing a new digital system and expanding its operational capabilities, Option B (New / Expanded Network) has been selected for this assessment. Option B is the most suitable approach because the organization does not currently operate a mature, integrated enterprise network or project management system. Instead, it is in the process of establishing a new technological environment to support the Prismo Constructions platform. This option allows the assessment to focus on designing and securing the expanded network infrastructure required for the successful and secure operation of the new system.

The scope of this analysis covers several key areas. First, it examines the current IT and network environment of the organization, including hardware, internet connectivity, existing software systems, communication methods, and basic security controls. Second, it provides an overview of the planned Prismo Constructions system, including its main functionalities, user roles, data storage requirements, and access patterns from both office locations and remote construction sites. Third, it defines the boundaries of the new or expanded network that will be required to support the digital transformation. Finally, this section identifies relevant assumptions and constraints that will guide the vulnerability assessment, risk analysis, and secure network design activities in the later parts of this report.

By establishing a clear understanding of the client's business context and technological environment, this section ensures that all subsequent security recommendations, risk treatment strategies, and ISO/IEC 27001 aligned controls are practical, relevant, and aligned with the real operational needs of Prismo Constructions (PVT) Ltd.

1.2 Client Organization Profile

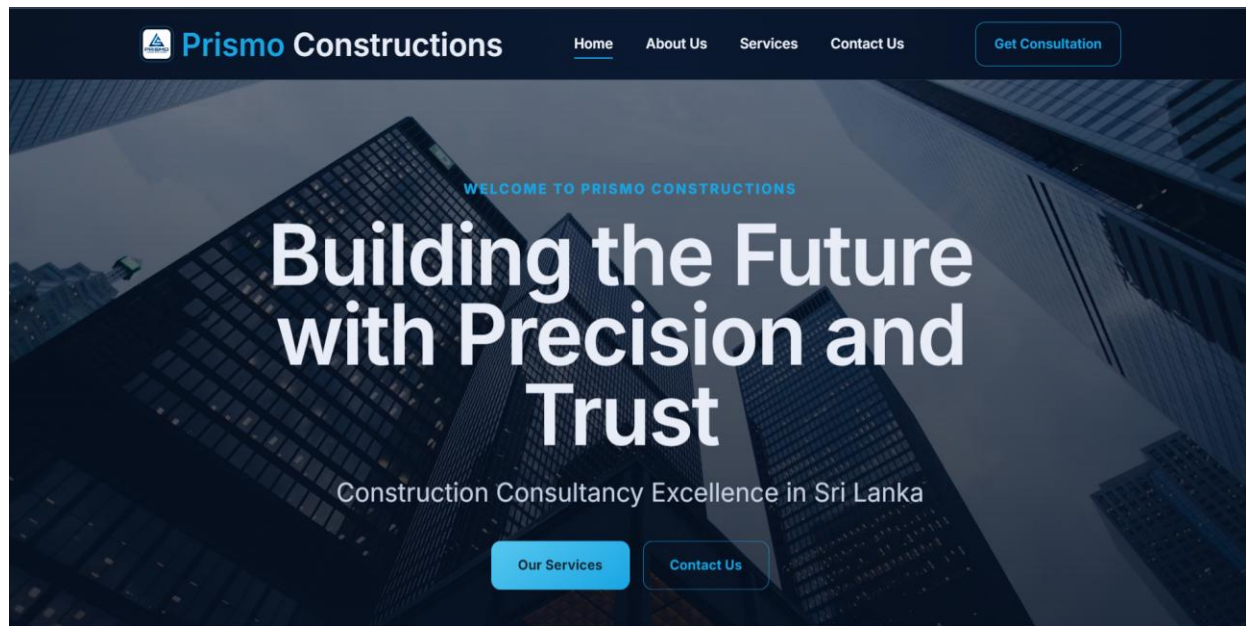


Figure 1.2.1: Figure Official Website of Prismo Constructions

Prismo Constructions (PVT) Ltd is a Sri Lankan construction consultancy firm that provides professional advisory and consultation services to clients involved in building and infrastructure projects. The organization operates within the construction industry, specifically focusing on construction consultancy services. Its current nature of business involves offering expert guidance on project planning, design coordination, cost estimation, and related consultancy activities. Client interactions and project updates are largely managed through traditional methods such as email, telephone, and messaging applications.

The company is currently in an expansion phase. It intends to extend its service offerings beyond consultancy into full construction project management. This strategic expansion requires the organization to manage complete construction projects, coordinate site activities, track daily progress, assign tasks to site personnel, share project documents, and handle client approvals in a more structured and efficient manner. To support this transformation, Prismo Constructions (PVT) Ltd. plans to implement a digital project management platform known as Prismo Constructions.

Prismo Constructions (PVT) Ltd is a relatively small organization that is in the process of growing its operational capacity. It has recently appointed new staff members to support the expanded construction management function. The company is based in Sri Lanka and currently operates primarily from its office location, with increasing activity expected at construction sites as project management services commence.

The organization maintains an existing website (<https://prismoconstructions.com/>), which currently functions as a marketing and informational platform. The website provides basic company information, service descriptions, and contact details. However, it does not support operational project management activities such as progress tracking, task management, document sharing, or client collaboration.

The organizational structure relevant to digital transformation includes several key roles. The Chief Executive Officer (CEO) provides overall strategic direction and oversight of the portfolio of projects. The Project Manager is responsible for creating and managing projects, setting milestones, assigning tasks, and monitoring overall project status. Site Engineers operate at construction sites and are responsible for

recording daily progress, uploading site photographs, reporting issues, and updating task status. Clients (project owners) require secure access to view project progress, review documents, and provide approvals. An Administrative Officer supports general administrative and coordination activities within the organization.

This organizational profile highlights that Prismo Constructions (PVT) Ltd is transitioning from a primarily consultancy-based operation to a more complex construction management environment. The introduction of new roles, increased data handling requirements, and the planned implementation of Prismo Constructions create a clear need for a secure and well-structured network environment to support the expanded operations.

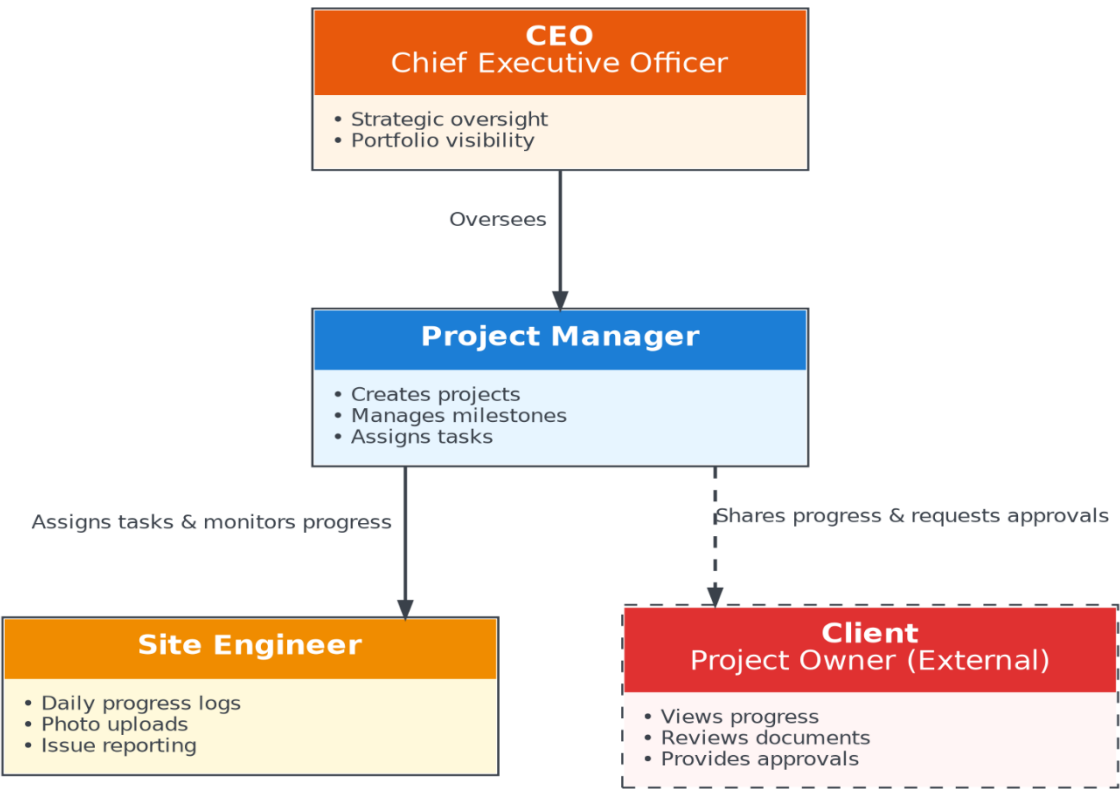


Figure 1.2.2: Organizational Structure of Prismo Constructions (Relevant to Prismo Constructions (PVT) Ltd)

The diagram illustrates the key roles involved in the Prismo Constructions (PVT) Ltd system. The CEO provides strategic oversight. The Project Manager is responsible for project creation, task assignment, and overall coordination. Site Engineers operate at construction sites and report progress. Clients (external project owners) access the system to view progress and provide approvals. The Administrative Officer supports general coordination activities.

1.3 Business Context and Digital Transformation Need

Prismo Constructions (PVT) Ltd currently conducts a significant portion of its operational activities using manual and semi-manual processes. Client communication, project updates, progress reporting, and document sharing are primarily handled through email, WhatsApp messages, telephone calls, and physical documents. Project-related information is often scattered across individual devices, email inboxes, and informal messaging channels. As a result, there is limited centralized visibility of project status, and coordination between office staff and site personnel relies heavily on informal communication.

These manual practices create several operational challenges. Information is frequently delayed or incomplete, making it difficult for management to obtain a real-time view of project progress. Document version control is weak, increasing the risk of using outdated information. Tracking task completion and site issues becomes inconsistent, and client approvals are often handled through unstructured email exchanges. As the organization begins to handle more complex construction management responsibilities, these inefficiencies are expected to increase, leading to potential delays, miscommunication, reduced accountability, and higher operational risk.

The decision to expand into construction management is driven by the organization's strategic intention to broaden its service portfolio and increase business value. Moving beyond consultancy services allows Prismo Constructions (PVT) Ltd to take greater responsibility for project execution, improve client relationships, and create new revenue opportunities. However, this expansion also introduces higher operational complexity. The company must now manage project timelines, assign and monitor site tasks, capture daily progress with photographic evidence, handle client documentation, and support formal approval workflows.

To effectively support this expanded scope of work, Prismo Constructions (PVT) Ltd requires a structured digital project management platform. The proposed system, Prismo Constructions, is designed to centralize project information, enable role-based access for internal staff and clients, support daily progress logging with photo uploads, facilitate task assignment and tracking, and provide a controlled environment for document sharing and client approvals. Without such a platform, the organization would continue to rely on fragmented manual methods that are unsuitable for managing multiple construction projects efficiently and securely.

The primary business objectives of this digital transformation are to improve operational efficiency, increase visibility and control over project activities, enhance communication between the office, site teams, and clients, reduce errors caused by manual handling of information, and establish a more professional and scalable project management capability. Achieving these objectives will enable Prismo Constructions (PVT) Ltd to successfully support its expansion into construction management while laying the foundation for secure and structured digital operations.

1.4 Current IT and Network Environment (As-Is)

Prismo Constructions (PVT) Ltd currently operates with a relatively simple and limited information technology environment that is typical of a small consultancy organization in the early stages of digital expansion. The existing hardware primarily consists of standard laptops and desktop computers used by office staff, along with basic peripheral devices such as printers and scanners. There is no evidence of a dedicated on-premises server infrastructure or advanced networking equipment beyond standard office routers and switches required for basic internet access.

Internet connectivity is provided through a conventional broadband service from a local Internet Service Provider. This connection supports general office activities such as email communication, web browsing, and access to cloud-based messaging tools. However, the current network is not designed to support a centralized project management system, secure remote access from construction sites, or structured multi-user collaboration.

The only existing software system of note is the organization's marketing website (<https://prismoconstructions.com/>). This website serves as an informational and promotional platform, providing company details, service descriptions, and contact information. It does not include any operational project management functionality, client portals, document management features, or secure login capabilities for internal staff or clients.

Communication within the organization and with clients is predominantly carried out through informal digital channels. Email is the primary formal communication method, while WhatsApp and telephone calls are extensively used for day-to-day coordination, progress updates, and quick decision-making. These methods, while convenient, lack structure, auditability, and centralized record-keeping.

Data storage practices are similarly unstructured. Project-related documents, photographs, and correspondence are typically stored on individual laptops, personal email accounts, or shared messaging platforms. There is no centralized document repository or controlled version management system. As a result, important project information is fragmented and difficult to retrieve in a consistent manner.

Existing security controls are basic. Computers are generally protected with standard antivirus software and password-based login access. However, there is no formal password policy, multi-factor authentication, network segmentation, centralized access control, or systematic backup procedure. Logging, monitoring, and incident response mechanisms are also absent.

The limitations of the current environment are significant in the context of the planned expansion. The existing IT setup lacks the capacity, structure, and security controls required to support a multi-user project management platform such as Prismo Constructions. It does not provide secure remote access for Site Engineers working at construction sites, controlled client access to project information, centralized data storage, or adequate protection for sensitive project and client data. These limitations confirm the need for a carefully designed and secured expanded network environment to support the organization's digital transformation.

Table 1.4.1 Comparison of Current Environment (As-Is) and Planned Environment (To-Be)

Aspect	Current Environment (As-Is)	Planned Environment (To-Be with Prismo Constructions)
Project Management	Manual coordination using email, phone and WhatsApp	Centralized digital project and portfolio management
Progress Tracking	Informal messages and verbal updates	Daily progress logs with photo uploads
Task Management	No structured task assignment system	Task creation, assignment to Site Engineers, and status tracking
Document Sharing	Email attachments and physical documents	Controlled document sharing within the system
Client Communication	Unstructured email and messaging	Client login, progress viewing, and formal approval workflow
Data Storage	Scattered across individual devices and inboxes	Centralized database with structured project records
User Access	No role-based system	Role-based access (CEO, Project Manager, Site Engineer, Client)
Remote Access	Not formally supported	Secure access from construction sites and client locations
Security Controls	Basic antivirus and simple passwords	Stronger authentication, access control, and data protection
Visibility for Management	Limited and delayed	Real-time portfolio and project status visibility
Network Environment	Basic office internet connectivity	Expanded network supporting office, site, and remote client access
Audit & Accountability	Weak / informal	System logs and traceable user actions

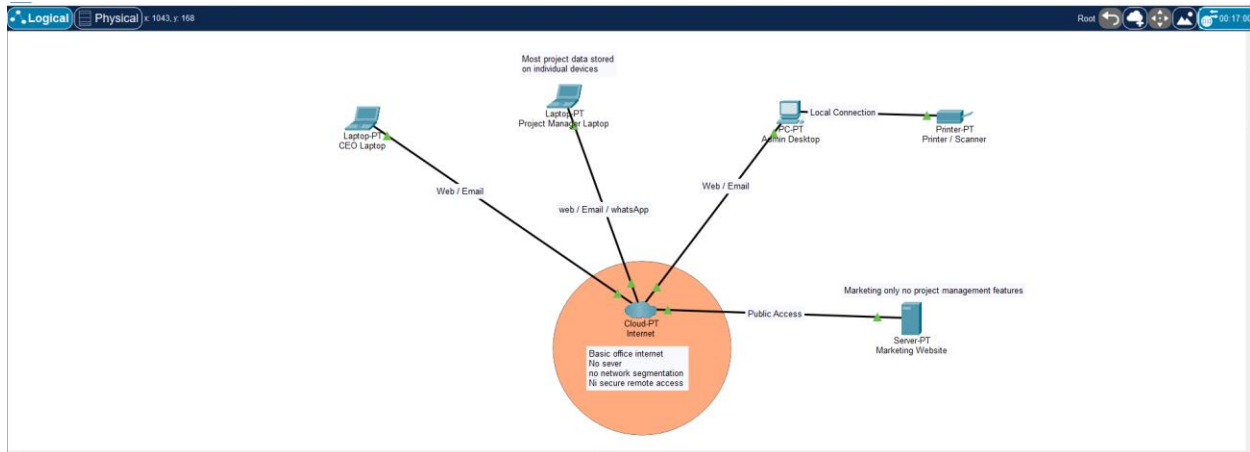


Figure 1.4.1: Simple Current Network Environment (As-Is) of Prismo Constructions

This diagram illustrates the current limited network environment of Prismo Constructions (PVT) Ltd. Staff use individual laptops and desktops connected to basic internet services. Project-related communication and data storage are handled mainly through email, WhatsApp, and local devices. The existing website functions only as a marketing platform. There is no centralized server, network segmentation, or structured remote access capability.

1.5 Planned New System – Prismo Constructions Overview

Prismo Constructions is the proposed web-based project management platform that Prismo Constructions (PVT) Ltd intends to implement to support its expansion into construction management. The primary purpose of Prismo Constructions is to replace the current fragmented and manual methods of project coordination with a centralized, structured, and accessible digital system. The platform is designed to improve visibility of project progress, streamline task management, enhance communication between internal teams and clients, and provide a controlled environment for document sharing and formal approvals.

The main modules and functionalities of Prismo Constructions include project and portfolio management, task and assignment management, site progress tracking, and client collaboration. Project Managers will be able to create projects, define milestones, and monitor overall project status. Site Engineers will be able to submit daily progress logs, upload site photographs, and report issues. Clients will have secure access to view project progress, download relevant documents, and respond to approval requests. The system will also support task creation, assignment to site personnel, status updates, and completion tracking.

Prismo Constructions will serve multiple user roles with clearly defined access requirements. The Chief Executive Officer will have high-level portfolio visibility. Project Managers will have full operational control over projects and tasks. Site Engineers will have access limited to the projects and tasks assigned to them. Clients will be granted controlled, read-focused access to their own projects, including the ability to review progress and respond to approval requests. Administrative staff may support limited coordination functions. Role-based access control will be essential to ensure that each user can only view and perform actions appropriate to their responsibilities.

The system will store several categories of sensitive and operationally important data. These include project records and milestone information, task details and status updates, daily progress logs, site photographs, client and internal documents, approval records, and user account credentials. Because this data includes

both business-critical and potentially confidential client information, strong confidentiality, integrity, and availability protections will be required.

Users will access Prismo Constructions from multiple locations. Office-based staff will access the system from the company premises. Site Engineers will require remote access from construction sites using laptops or mobile devices. Clients will access the platform over the internet from their own locations. This multi-location access model significantly increases the importance of secure authentication, encrypted communication, and controlled remote access.

From a technology perspective, Prismo Constructions is planned as a modern web application using React for the frontend, Spring Boot for the backend, and a relational database (MySQL) for data storage. The system will be delivered as a web-based platform accessible through standard browsers, supporting both desktop and mobile access as required by different user groups.

Overall, Prismo Constructions represents a significant technological and operational advancement for Prismo Constructions (PVT) Ltd. Its successful and secure implementation will depend on an appropriately designed and protected network environment capable of supporting centralized data storage, role-based access, and secure connectivity from both internal and external locations.

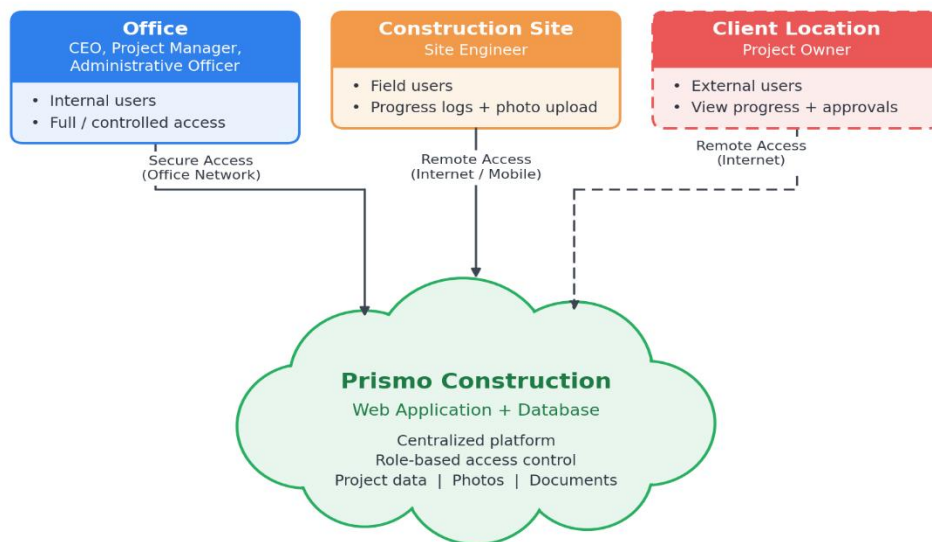


Figure 1.5.1: High-Level Access Locations for Prismo Constructions

This diagram illustrates the main locations from which users will access the Prismo Constructions system. Office-based staff (CEO, Project Manager, and Administrative Officer) will access the system from the company premises. Site Engineers will connect remotely from construction sites to submit daily progress updates and photographs. Clients will access the platform over the internet to view project progress and respond to approval requests. All access routes connect to the centralized Prismo Constructions application and database.

1.6 Scope of the New / Expanded Network

The current network environment of Prismo Constructions (PVT) Ltd is insufficient to support the planned digital transformation. The existing setup is limited to basic office internet connectivity and individual computing devices. It lacks centralized servers, structured network segmentation, secure remote access capabilities, formal access control mechanisms, and adequate protection for multi-user systems. As a result, it cannot reliably or securely support a centralized platform such as Prismo Constructions, especially when users need to connect from construction sites and external client locations.

To address these limitations, several components of the network environment must be expanded or newly designed. The organization will require a more structured office network capable of supporting internal users accessing the Prismo Constructions system. Secure remote access solutions will be necessary to allow Site Engineers working at construction sites to connect safely to the platform. Controlled external access must also be provided for clients who need to view project progress and respond to approval requests. In addition, appropriate hosting infrastructure, whether on-premise or cloud-based, must be established to run the application and store project data securely.

Office network requirements include reliable internal connectivity, basic network segmentation to separate user devices from critical systems where possible, secure authentication for staff, and controlled access to the Prismo Constructions application and its supporting database. The office environment should also support secure communication channels and basic monitoring of network activity related to the new system.

Remote access requirements are particularly important. Site Engineers will need the ability to log progress, upload photographs, and update task status from construction sites, which may have varying levels of internet connectivity and limited physical security. Clients will require secure browser-based access to their project information without being granted unnecessary privileges. These remote access scenarios increase the need for strong authentication, encrypted connections, and carefully controlled permissions.

Hosting considerations form another critical part of the expanded network scope. Prismo Constructions (PVT) Ltd choose to host Prismo Constructions on a local server within the office environment or on a cloud platform. Each approach has different implications for security, availability, maintenance, and cost. Regardless of the hosting model selected, the network design must ensure secure access to the application, protection of stored data, and appropriate backup and recovery arrangements.

Integration with the existing marketing website is expected to remain limited. The current website functions primarily as a public informational platform and is not intended to become part of the operational Prismo Constructions system. Any future linkage, such as a simple redirection or contact form, should be carefully controlled so that it does not introduce unnecessary security exposure to the project management environment.

In summary, the scope of the new and expanded network focuses on establishing a secure and practical environment capable of supporting Prismo Constructions for office users, site-based staff, and external clients. This expanded scope forms the basis for vulnerability assessment and the secure network architecture design presented in the later sections of this report.

1.7 Stakeholders Related to Network and Security

Several internal and external stakeholders have a direct interest in the security and reliability of the expanded network environment that will support Prismo Constructions.

Internal stakeholders

include the Chief Executive Officer, Project Managers, Site Engineers, and Administrative staff. The **CEO** requires confidence that project and client information is protected and that the system provides reliable visibility across the project portfolio. Any security incident or prolonged system unavailability would affect strategic oversight and organizational reputation. **Project Managers** depend on the system for creating projects, assigning tasks, monitoring progress, and managing client communications. They have a strong interest in ensuring that project data remains accurate, accessible only to authorized users, and protected from unauthorized modification or loss. **Site Engineers** will use the system from construction sites to submit daily progress updates, upload photographs, and report issues. Their primary concerns relate to reliable remote access and the ability to submit information securely without complex technical barriers. **Administrative staff** may handle supporting documentation and coordination tasks and therefore require controlled access while ensuring that sensitive information is not exposed unnecessarily.

External stakeholders

primarily include **Clients** (project owners). Clients will access Prismo Constructions to view project progress, review documents, and respond to approval requests. They have a clear interest in the confidentiality of their project information and in the integrity of the progress data and documents presented to them. A security failure that exposes client data or presents incorrect project information would damage trust and could have contractual and reputational consequences for Prismo Constructions (PVT) Ltd.

In addition to operational roles, **IT and system support responsibilities** are relevant to network and security considerations. Although Prismo Constructions (PVT) Ltd is a small organization and may not currently have a dedicated internal IT department, the implementation of Prismo Constructions will require individuals or external support providers responsible for system administration, user account management, backup procedures, and basic security monitoring. These roles are critical for maintaining access controls, applying updates, and responding to potential security incidents.

Collectively, these stakeholders demonstrate that network and information security is not only a technical concern but also a business requirement. Each group depends on the confidentiality, integrity, and availability of Prismo Constructions and the underlying network. Their needs and expectations must therefore be considered when identifying vulnerabilities, assessing risks, and designing appropriate security controls in the subsequent sections of this assessment.

Table 1.7.1: Stakeholders and Their Interest in Network and Information Security

Stakeholder	Type	Role in Prismo Constructions	Interest in Network & Information Security	Priority
CEO	Internal	Strategic oversight and portfolio visibility	Requires high system availability and protection of overall project and business information	High
Project Manager	Internal	Creates projects, assigns tasks, monitors progress	Needs secure access to project data, protection from unauthorized changes, and reliable system availability	High
Site Engineer	Internal	Submits daily progress, uploads photos, reports issues	Requires secure and reliable remote access from construction sites	High
Administrative Officer	Internal	Supports coordination and administrative tasks	Needs controlled access and protection of internal documents	Medium
Client (Project Owner)	External	Views progress, reviews documents, gives approvals	Requires confidentiality of project information and integrity of progress data	High
System / IT Support	Internal / External	Manages system access, backups, and basic security	Responsible for implementing and maintaining security controls	High

Table summarizes the key stakeholders related to the Prismo Constructions system and their interest in network and information security. Internal users such as the CEO, Project Manager, and Site Engineer depend on the confidentiality, integrity, and availability of project data. External clients require assurance that their project information remains protected. System support roles are responsible for maintaining appropriate security controls. These stakeholder interests form an important input for the vulnerability and risk assessment in the later stages of this report.

1.8 Assumptions

The following assumptions have been made in conducting this Client and Network Environment Analysis and will guide the subsequent vulnerability assessment and secure network design:

- Prismo Constructions (PVT) Ltd will proceed with the implementation of the Prismo Constructions platform as part of its expansion into construction management.
- The organization currently operates with a limited and basic IT environment and does not have a mature, segmented enterprise network or formal information security management system.
- Prismo Constructions will be accessed by internal users (CEO, Project Managers, Site Engineers, and administrative staff) as well as external clients.

- Site Engineers will require remote access to the system from construction sites using laptops or mobile devices.
- Clients will access the system over the internet through standard web browsers.
- The system will store sensitive operational and client-related data, including project records, progress photographs, documents, and user credentials.
- The organization has limited internal IT support capacity and may rely on external technical assistance for system hosting, maintenance, and security configuration.
- Basic internet connectivity will be available at both the office and most construction sites, although the quality and reliability of site connectivity may vary.
- The existing marketing website will remain separate from the operational Prismo Constructions system and will not form part of the core secure network design.

Constraints

Several practical constraints influence the scope and recommendations of this assessment:

- **Budget limitations:** As a small organization in an expansion phase, Prismo Constructions (PVT) Ltd is expected to have limited financial resources for advanced security infrastructure and enterprise-grade solutions.
- **Time constraints:** The digital transformation is being planned within a relatively short academic and operational timeframe, which limits the complexity of the proposed network and security controls.
- **Technical capacity:** The organization currently has limited in-house IT and cybersecurity expertise, which affects the feasibility of highly complex security architectures.
- **Scale of operations:** The initial implementation of Prismo Constructions is expected to support a relatively small number of concurrent users and projects, which influences the scale of the recommended network design.
- **Infrastructure limitations:** The current office environment does not include advanced networking or server infrastructure, and significant upgrades may need to be introduced gradually.

These assumptions and constraints ensure that the vulnerability assessment and the proposed secure network architecture remain realistic, practical, and aligned with the actual operational context of Prismo Constructions (PVT) Ltd.

1.9 Summary of Step 1

The analysis of Prismo Constructions (PVT) Ltd client and network environment confirms that the organization is in a critical transition phase. It is expanding from a primarily consultancy-based operation into construction project management and plans to implement a new digital platform, Prismo Constructions, to support this growth. The current IT and network environment is limited, relying on basic office connectivity, individual devices, informal communication channels, and minimal security controls. These conditions are insufficient to support a multi-user project management system that will store sensitive project data, progress records, photographs, documents, and user credentials, and that must be accessed from both the office and remote construction sites.

Key findings from this analysis include the absence of a centralized project management system, the fragmented nature of current data storage and communication practices, limited existing security controls, and the introduction of new user roles with different access needs. The planned Prismo Constructions system will significantly increase the organization's dependence on reliable and secure network infrastructure, particularly for remote access by Site Engineers and controlled external access by clients.

This environment analysis provides the essential foundation for the remaining stages of the assessment. It establishes a clear understanding of the assets that must be protected, the users who will interact with the system, the locations from which access will occur, and the practical constraints facing the organization. These insights directly support the identification of vulnerabilities, the assessment of information security risks, and the design of a realistic and secure expanded network architecture aligned with the requirements of Prismo Constructions and the principles of ISO/IEC 27001.

2. Network Architecture Analysis / Proposed Network Design

2.1 Introduction

This section presents the proposed network architecture required to support Prismo Constructions (PVT) Ltd digital transformation through the implementation of the Prismo Constructions platform. Building on the findings of Task 1, which established that the organization's current IT environment is limited and insufficient for a multi-user project management system, this section focuses on defining a practical and secure expanded network design.

The analysis in Task 1 identified several critical gaps, including the absence of centralized infrastructure, lack of structured remote access, weak security controls, and fragmented data storage practices. These limitations confirmed the need for a new or expanded network environment capable of supporting office-based users, Site Engineers working at construction sites, and external clients accessing the system remotely.

The purpose of this section is to translate those requirements into clear high-level network architecture. It outlines the key network requirements, design principles, logical network zones, major components, and access methods necessary to operate Prismo Constructions securely and reliably. The proposed design aims to balance practicality with essential security controls, taking into account the organization's size, limited technical resources, and expansion stage.

This section provides the architectural foundation for the vulnerability identification and risk assessment activities that follow. By defining how users, applications, and data will be connected and protected, it enables a more accurate evaluation of potential security weaknesses and the selection of appropriate controls in later stages of the report.

2.2 Network Requirements Analysis

The design of the expanded network for Prismo Constructions (PVT) Ltd is driven by clear business, operational, and security requirements arising from the implementation of Prismo Constructions and the organization's move into construction management.

Business requirements

center on the need for a reliable and structured digital environment that can support centralized project management. The organization requires the ability to create and manage projects, assign tasks, track site progress, share documents, and handle client approvals in a controlled manner. The network must therefore enable consistent access to the Prismo Constructions platform for all relevant users while protecting business and client information.

User access requirements

vary according to role and location. Office-based users, including the CEO, Project Managers, and administrative staff, require stable internal access to the system from the company premises. Site Engineers need to secure remote access from construction sites so they can submit daily progress logs, upload photographs, and update task status. Clients require controlled external access over the internet to view project progress, review documents, and respond to approval requests. These different access patterns must be supported without exposing the core system to unnecessary risk.

Application requirements

are defined by the Prismo Constructions platform itself. The system is a web-based application that depends on continuous connectivity between users, the application layer, and the database. It must support role-based access, secure login, file uploads (particularly site photographs), document storage, and real-time or near real-time updates of project information. The network must therefore provide reliable connectivity and appropriate pathways between users and the application environment.

Data sensitivity and security requirements

are significant. Prismo Constructions will store project records, task details, progress logs, site photographs, client documents, approval records, and user credentials. Much of this information is confidential and business-critical. The network must therefore support strong authentication, controlled access, protection of data in transit, and safeguards against unauthorized access or data leakage.

Availability and performance requirements

are also important. Project Managers and Site Engineers need dependable access during working hours to maintain accurate progress tracking and coordination. While extreme high-availability infrastructure may not be realistic for a small organization at this stage, the network design should still aim for stable performance, reasonable response times, and basic resilience so that day-to-day operations are not disrupted by simple connectivity or access failures.

Together, these requirements define the functional and security expectations that the proposed network architecture must satisfy. They form the basis for the design principles, network zones, and access controls described in the following sections.

2.3 High-Level Network Design Principles

The proposed network architecture for Prismo Constructions (PVT) Ltd is guided by a set of established security and design principles that are appropriate for a small organization implementing a new digital platform. These principles ensure that the network is both practical to implement and capable of providing meaningful protection for Prismo Constructions and its associated data.

Defense in Depth

is applied by combining multiple layers of protection rather than relying on a single control. This includes secure access methods, basic network separation, authentication controls, and endpoint protection. Even if one control is weak or bypassed, other layers remain in place to reduce overall risk.

Least Privilege

is a core principle of the design. Users are granted only the access necessary for their role. The CEO, Project Manager, Site Engineer, and Client each have different levels of access to Prismo Constructions. This limits the potential damage that could result from compromised accounts or insider misuse.

Network Segmentation

is introduced at a practical level by separating different types of traffic and user groups where possible. Office users, the application/database environment, and remote/external access are treated as distinct zones. This reduces the likelihood that a compromise in one area will immediately affect the entire system.

Secure Remote Access

is treated as a design requirement rather than an afterthought. Because Site Engineers and Clients must connect from outside the office, the architecture prioritizes controlled and encrypted remote access instead of exposing internal systems directly to the internet.

Simplicity and Practicality

are also important principles. Prismo Constructions (PVT) Ltd is a small organization with limited IT resources and budget. The design therefore avoids unnecessary complexity and focuses on controls that are realistic to implement and maintain at the current stage of expansion.

These principles align directly with the organization's expansion needs. As Prismo Constructions (PVT) Ltd moves from manual consultancy operations to digital construction project management, the network must support new users, new data types, and new access locations without introducing unmanaged risk. By applying defense in depth, least privilege, segmentation, and secure remote access in a practical manner, the proposed architecture provides a solid foundation for the secure operation of Prismo Constructions while remaining suitable for the organization's size and capacity.

2.4 Proposed Logical Network Architecture

The proposed logical network architecture for Prismo Constructions (PVT) Ltd is designed to support the secure operation of Prismo Constructions while remaining practical for a small organization in the early stages of digital expansion. The architecture separates different types of users and system components into logical zones. This separation improves security, supports role-based access, and reduces the impact of potential security incidents.

At a high level, the architecture consists of four main logical zones: the Office User Zone, the Server / Application Zone, the Remote Access Zone, and a limited Public / External Access path. Prismo Constructions sits at the centre of this design as the primary business application, supported by its database and accessed by different user groups through controlled pathways.

Office User Zone

This zone represents the internal office environment where the CEO, Project Managers, and administrative staff operate. Users in this zone connect through the office network using laptops or desktops. They require reliable access to Prismo Constructions for project creation, task management, monitoring, and administrative activities. Traffic from this zone is trusted more than external traffic but is still subject to authentication and access control before reaching the application.

Server / Application Zone

This is the most critical zone in the architecture. It hosts the Prismo Constructions application and its associated database. All core business data, including project records, progress logs, photographs, documents, and user credentials, resides in this zone. Access to this zone is restricted and should only be possible through controlled interfaces. Direct exposure of the database or internal application services to the public internet is avoided. This zone is the primary focus of protection in the overall design.

Remote Access Zone

This zone supports users who need to connect from outside the office. Site Engineers working at construction sites fall into this category. They require the ability to log daily progress, upload photographs,

and update task status. Remote access is provided through secure methods such as encrypted web access or a lightweight VPN-style connection. This zone acts as a controlled entry path so that remote users do not connect directly into the core Server / Application Zone without safeguards.

Public / External Access Path (Limited)

Clients need controlled access to view project progress, download relevant documents, and respond to approval requests. This access is provided through the Prismo Constructions web interface over the internet. It is treated as an external access path with strong authentication and limited privileges. Clients are not given access to internal office systems or unrestricted parts of the network. The existing marketing website remains separate and is not integrated into the operational application zone.

Prismo Constructions fits into this architecture as the central application hosted within the Server / Application Zone. Office users access it internally, Site Engineers access it through the Remote Access Zone, and Clients access it through the controlled external path. This structure allows the organization to support all required user groups while maintaining logical separation between internal operations, core systems, and external access.

The proposed logical architecture provides a clear and practical foundation for securing Prismo Constructions. It reflects the real access needs of Prismo Constructions (PVT) Ltd and creates distinct zones that can be protected according to their sensitivity and exposure.

Table 2.4.1: Proposed Network Zones

Zone	Main Users / Systems	Purpose	Trust Level	Key Security Controls
Office User Zone	CEO, Project Manager, Administrative Officer	Internal access to Prismo Constructions	Medium-High	Authentication, role-based access
Server / Application Zone	Prismo Constructions Application + Database	Host core system and sensitive data	Highest	Restricted access, firewall protection
Remote Access Zone	Site Engineers (Construction Sites)	Submit progress, photos, and task updates	Medium	Encrypted access, strong authentication
External / Client Access	Clients (Project Owners)	View progress, documents, and give approvals	Low-Medium	Limited privileges, encrypted web access

2.5 Key Network Components

The proposed expanded network for Prismo Constructions (PVT) Ltd consists of a practical set of components selected to support Prismo Constructions securely while remaining realistic for a small organization. Each component plays a specific role in enabling connectivity, protecting data, and controlling access.

Firewall

A firewall is a critical component of the proposed architecture. It acts as the primary control point between

the internal network, the application environment, and external connections. The firewall is used to restrict unnecessary incoming traffic, allow only required access to Prismo Constructions, and separate different logical zones. It helps reduce exposure of the application and database to direct internet threats.

Router / Switch

A router provides connectivity between the office network and the internet, while switches support internal communication between office devices. These components form the basic networking foundation that allows office users to connect to Prismo Constructions and enables controlled routing of remote access traffic. Advanced enterprise-grade equipment is not required at this stage, but reliable and correctly configured devices are essential.

Application Server / Hosting Environment

The application server hosts the Prismo Constructions web application (React frontend and Spring Boot backend). This component can be implemented either on a local server within the organization or on a cloud hosting platform. It is responsible for processing user requests, managing application logic, and handling interactions with the database. Because it is central to system operations, it must be protected through restricted access and regular updates.

Database Server

The database server stores all critical Prismo Constructions data, including project records, task details, progress logs, photographs metadata, documents, approval records, and user credentials. Whether hosted on the same server as the application or on a separate instance, the database is one of the most sensitive components in the architecture. Access to it should be limited to the application layer, and direct external access should not be permitted.

Remote Access Solution

A secure remote access solution is required to support Site Engineers working from construction sites and to enable controlled client access. This may be implemented through secure HTTPS web access to Prismo Constructions, supported by strong authentication, or through a lightweight VPN for internal users who need broader access. The remote access component ensures that external connections are encrypted and controlled rather than left open to the public internet.

Endpoint Devices (Laptops)

Laptops used by the CEO, Project Managers, and Site Engineers are important components of the overall environment. These devices are used to access Prismo Constructions, store temporary working files, and upload site photographs. Because they operate both inside and outside the office, they must be protected with basic endpoint security measures such as strong passwords, up-to-date antivirus software, and careful handling of sensitive data.

Together, these components form a practical and coherent network environment capable of supporting Prismo Constructions. The design prioritizes essential security controls and operational needs while remaining suitable for the size, budget, and technical capacity of Prismo Constructions (PVT) Ltd.

2.6 Access Control and Connectivity

Access control and connectivity arrangements are designed to ensure that each user group can reach Prismo Constructions in a manner appropriate to their role and location, while minimizing unnecessary exposure of the system.

Office Staff Access

Office-based users, including the CEO, Project Managers, and administrative staff, will access Prismo Constructions from the internal office network. These users connect through standard office laptops or desktops using the organization's internet connection. Because they operate within a more controlled environment, their connectivity path is considered relatively trusted compared with external users. Access is still protected through user authentication and role-based permissions within the application.

Site Engineer Remote Access

Site Engineers require the ability to use Prismo Constructions from construction sites. Their access is remote and often takes place over public or less-trusted internet connections. To support this need securely, Site Engineers will connect to the system through encrypted web access (HTTPS) or a controlled remote access method. This allows them to submit daily progress logs, upload photographs, and update task status without requiring direct exposure of internal systems. Their access rights within Prismo Constructions are limited to the projects and tasks assigned to them.

Client Remote Access

Clients (project owners) access Prismo Constructions over the internet from their own locations. Their connectivity is external and must be carefully controlled. Clients are provided with secure login access to a limited set of functions, such as viewing project progress, reviewing shared documents, and responding to approval requests. They are not granted access to internal office resources or unrestricted parts of the system. All client communication with the platform should occur over encrypted connections.

Authentication Approach (High-Level)

A centralized authentication mechanism is required to support secure access for all user groups. Each user will have a unique account with credentials appropriate to their role. Access to Prismo Constructions will be granted only after successful authentication. Role-based access control will then determine what information and functions each user can see or use. For remote users (Site Engineers and Clients), authentication is especially important because their connections originate from outside the office environment. At a later stage, stronger authentication measures such as multi-factor authentication can be considered to further improve security.

This structured approach to access control and connectivity ensures that office staff, Site Engineers, and Clients can all use Prismo Constructions effectively, while maintaining clear boundaries between internal, remote, and external access paths.

Table 2.6.1: Access Method Summary Table

User Group	Access Location	Access Method	Authentication	Access Level
CEO	Office	Internal Network	Username + Password	Portfolio & high-level visibility
Project Manager	Office	Internal Network	Username + Password	Full project management access
Site Engineer	Construction Site	Secure Remote Access (HTTPS)	Username + Password	Assigned projects & tasks only
Client	Remote (Internet)	Secure Web Portal (HTTPS)	Username + Password	View progress + submit approvals only
Administrative Officer	Office	Internal Network	Username + Password	Limited administrative access

2.7 Network Diagram

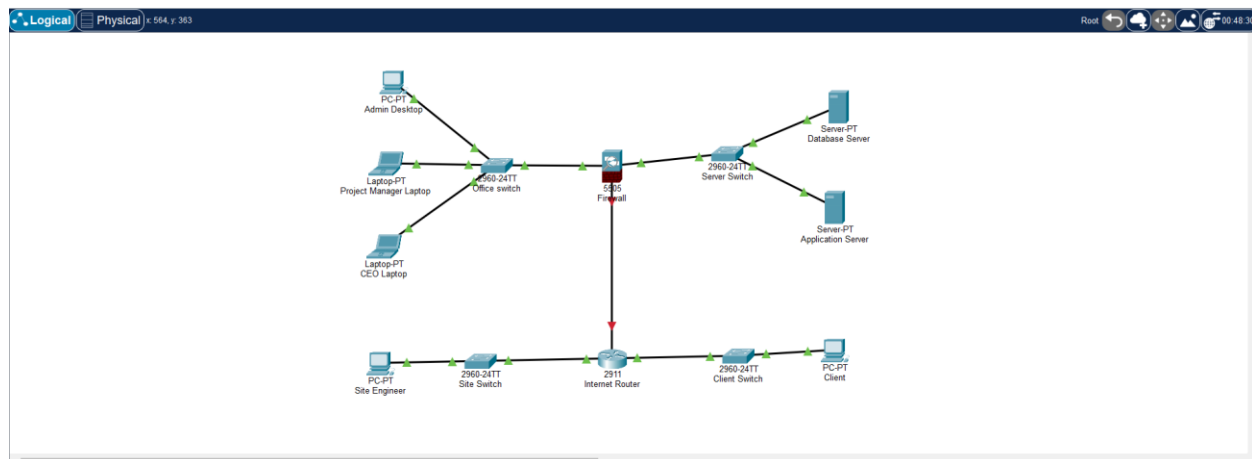


Figure 2.7.1: High Level Logical Network Architecture Diagram

The diagram illustrates the proposed logical network architecture designed to support Prismo Constructions at Prismo Constructions (PVT) Ltd. The architecture is divided into key zones to improve security and control.

The **Office User Zone** contains internal users such as the CEO, Project Manager, and Administrative staff, who access the system from the office network. The **Remote Access Zone** supports Site Engineers working at construction sites, allowing them to submit progress updates and photographs. The **External / Client Access** path enables clients to securely view project progress and respond to approval requests over the internet.

All external and remote traffic passes through a **Firewall**, which controls and filters access to the **Server / Application Zone**. This core zone hosts the Prismo Constructions application and the database containing project data, documents, photographs, and user credentials. Direct exposure of the application and database to the internet is avoided.

This logical separation supports the principles of network segmentation, controlled remote access, and protection of critical assets, while remaining practical for a small organization implementing a new digital platform.

2.8 Justification of the Proposed Design

The proposed logical network architecture is specifically tailored to the operational realities and expansion needs of Prismo Constructions (PVT) Ltd. As a small organization moving from consultancy services into construction project management, the company requires a solution that is secure enough to protect sensitive project and client data, yet practical enough to implement and maintain with limited IT resources and budget.

This design suits Prismo Constructions (PVT) Ltd because it focuses on essential controls rather than complex enterprise infrastructure. The architecture introduces clear logical zones, controlled remote access, and a protected application and database environment without requiring advanced or costly networking equipment. It supports the real access needs of office staff, Site Engineers working at construction sites, and external clients, while keeping the overall design simple and manageable.

The proposed architecture directly addresses the limitations identified in Task 1. The current environment lacks centralized infrastructure, structured remote access, role-based control, and adequate protection for project data. By introducing a dedicated Server / Application Zone, a firewall-controlled access path, and separate handling of remote and external users, the design removes the reliance on unstructured email and messaging channels. It also provides a foundation for centralized data storage and controlled user access, which were previously missing.

From a security perspective, the design applies practical segmentation and access control to reduce exposure of critical assets. Prismo Constructions and its database are placed in a protected zone rather than being directly accessible from the internet. Remote and client access is handled through controlled and encrypted pathways. These measures significantly improve the organization's security posture compared with the existing basic setup.

The architecture also considers scalability at an appropriate level. While it is designed for the organization's current and near-term needs, it can be expanded later if the number of users or projects increases. Additional security controls, such as stronger authentication or more refined monitoring, can be introduced gradually as the organization matures. This makes the design both suitable for the present stage of expansion and capable of supporting future growth without requiring a complete redesign.

Overall, the proposed network architecture provides a balanced and realistic solution. It addresses the key weaknesses of the current environment, supports the operational requirements of Prismo Constructions, and establishes a practical security foundation aligned with the size and capacity of Prismo Constructions.

2.9 Summary of Task 2

Task 2 has defined a practical and secure logical network architecture to support the implementation of Prismo Constructions at Prismo Constructions (PVT) Ltd. The proposed design responds directly to the limitations identified in Task 1 by moving the organization away from a basic, unstructured IT environment toward a controlled and expandable network model.

The key points of the proposed architecture are the separation of users and systems into logical zones, the protection of the Prismo Constructions application and database within a dedicated Server / Application Zone, and the controlled handling of remote and external access. Office staff connect through the internal network, Site Engineers access the system securely from construction sites, and Clients use a limited external access path. A firewall acts as the primary control point between these zones, helping to restrict unnecessary exposure of critical systems.

This design provides a clear structure for understanding where sensitive data resides, how different user groups connect, and which components are most critical to protect. As a result, it creates a solid foundation for the vulnerability identification and risk assessment activities in the next stages of the report. By defining the main assets, access paths, and trust boundaries, the architecture enables a more accurate evaluation of potential security weaknesses and the selection of appropriate controls aligned with the operational needs of Prismo Constructions (PVT) Ltd.

3. Initial Security and Vulnerability Identification

3.1 Introduction

This section focuses on the initial identification of security vulnerabilities within the current and planned network environment of Prismo Constructions (PVT) Ltd. Building on the findings of Task 1 and Task 2, the purpose of this analysis is to systematically identify weaknesses that could compromise the confidentiality, integrity, or availability of the Prismo Constructions platform and its associated data.

Task 1 established that Prismo Constructions (PVT) Ltd currently operates with a limited IT environment, relying heavily on manual processes, informal communication channels, and basic security controls. Task 2 then proposed a practical expanded network architecture to support Prismo Constructions, introducing logical zones, controlled remote access, and a protected application environment. While this proposed design improves upon the existing situation, it also introduces new attack surfaces and security dependencies that must be carefully examined.

The scope of this vulnerability identification covers both the weaknesses present in the current As-Is environment and the potential vulnerabilities associated with the proposed expanded network and Prismo Constructions system. Particular attention is given to network infrastructure, access control, data protection, remote access, endpoint security, and human-related weaknesses arising from the organization's expansion into construction management.

The approach used in this section is qualitative and risk-oriented. Vulnerabilities are identified through analysis of the organizational context, current practices, planned system architecture, and common security weaknesses relevant to small organizations implementing web-based project management systems. The identified vulnerabilities are grouped by category and linked to the assets and access paths defined in earlier tasks. This structured identification provides the necessary foundation for the formal risk assessment and treatment activities presented in Task 4.

3.2 Asset Identification (High-Level)

Before identifying vulnerabilities, it is necessary to establish a clear understanding of the key assets that require protection within the Prismo Constructions (PVT) Ltd environment. These assets form the foundation of the vulnerability and risk assessment.

Critical Information Assets

The most important information assets associated with Prismo Constructions include:

- Project data and records (project details, milestones, status, and progress information)
- Daily progress logs and site activity records
- Progress photographs and site images
- Client documents and approval records
- User account credentials and authentication data
- System logs and audit trails

These assets contain business-critical and sensitive information. Unauthorized access, modification, or loss of this data could affect project delivery, client trust, and organizational reputation.

Critical Systems and Applications

The primary system requiring protection is the Prismo Constructions web application. This includes:

- The application layer (frontend and backend services)
- The central database that stores project, user, and operational data
- File storage used for photographs and documents

Supporting systems such as user authentication mechanisms and any hosting environment (on-premise or cloud) are also considered critical, as their compromise would directly affect the availability and security of Prismo Constructions.

Key User Groups and Access Points

Several user groups interact with the system and therefore represent important access points:

- **CEO** – High-level portfolio access from the office
- **Project Managers** – Full operational access from the office
- **Site Engineers** – Remote access from construction sites for progress updates and photo uploads
- **Clients** – External access over the internet to view progress and submit approvals
- **Administrative staff** – Limited internal access

These access points are significant because they introduce different levels of trust and exposure, particularly where remote and external connections are involved.

Supporting Infrastructure Components

The expanded network environment includes several supporting components that must also be considered:

- Office laptops and endpoint devices
- Internet connectivity and networking equipment (router, switches)
- Firewall (proposed)
- Application and database hosting environment
- Remote access pathways

Although some of these components are still being introduced as part of the expanded network, they form part of the overall attack surface and must be included in the vulnerability identification process.

By identifying these critical information assets, systems, user groups, and infrastructure components, this section establishes a clear scope for the vulnerability analysis that follows. Protecting these assets is essential for the secure and successful operation of Prismo Constructions and for supporting Prismo Constructions (PVT) Ltd expansion into construction management.

3.3 Threat Landscape Overview

Understanding the threat landscape is essential for identifying meaningful vulnerabilities within Prismo Constructions (PVT) Ltd current and planned environment. As a small organization expanding into construction management and implementing a new digital platform, Prismo faces a combination of internal, external, and expansion-related threats.

Relevant Threat Categories

The most relevant threat categories for Prismo Constructions (PVT) Ltd include unauthorized access, data leakage, malware infection, misuse of privileges, phishing and social engineering, system unavailability, and weak control of remote connections. These threats are particularly significant because the organization is moving from informal, manual processes to a centralized digital system that stores sensitive project and client information.

Internal Threats

Internal threats arise from staff members and authorized users. These include accidental data exposure through incorrect sharing of documents or photographs, weak password practices, misuse of access privileges, and limited security awareness. As new Project Managers and Site Engineers are appointed, the risk of inconsistent security practices increases. Internal users also handle sensitive data on laptops and mobile devices, which raises the possibility of accidental loss or unauthorized disclosure.

External Threats

External threats originate from outside the organization. Common examples include cyber attackers attempting to exploit weak authentication, phishing attacks targeting staff credentials, malware delivered through email or compromised websites, and unauthorized attempts to access the Prismo Constructions (PVT) Ltd platform over the internet. Because clients will also access the system externally, poorly controlled external access paths could become entry points for attackers.

Threats Related to Remote Access and Expansion

The organization's expansion introduces additional threats linked to remote and site-based operations. Site Engineers will access Prismo Constructions from construction sites, often using portable devices over less-trusted networks. This increases exposure to insecure Wi-Fi, device theft, and interception of data in transit. The shift from informal communication tools such as WhatsApp and email to a centralized system also creates a period of transition risk, during which old insecure practices may continue alongside the new platform. Furthermore, the introduction of new user roles and increased data volumes expands the overall attack surface.

Overall, the threat landscape for Prismo Constructions (PVT) Ltd is shaped by its current low security maturity, its reliance on remote access, and the implementation of a new multi-user digital system. These threats provide the context for identifying specific vulnerabilities in the following section.

Table 3.3.0.1: Threat vs Vulnerability Mapping

Threat Category	Related Vulnerabilities	Possible Consequence
Unauthorized Access	Weak authentication, Absence of MFA, Insufficient RBAC, Shared/weak passwords, Weak remote access controls	Attackers or unauthorized users gain access to Prismo Constructions and project data
Data Leakage / Information Disclosure	Insecure handling of photos & documents, Unstructured data storage, Lack of encryption, Heavy use of email/WhatsApp, Lost/stolen devices	Sensitive project and client information is exposed
Malware Infection	Limited endpoint protection, Use of personal/mobile devices, Limited firewall protection	Devices or systems become infected, leading to data loss or further compromise
Privilege Misuse / Insider Threat	Insufficient role-based access control, Informal processes, New staff and expanding roles	Users access or modify information beyond their responsibilities
Phishing & Social Engineering	Limited security awareness, Weak passwords, Heavy reliance on email	Staff credentials are stolen and used for unauthorized access
System Unavailability / Disruption	Limited firewall protection, Insecure internet exposure, Weak remote access controls, Limited endpoint protection	Prismo Constructions becomes inaccessible, affecting project operations
Interception of Data in Transit	Weak remote access controls, Lack of encryption, Insecure internet exposure	Project data, photos, or credentials are intercepted during transmission
Device Loss or Theft	Use of personal/mobile devices at sites, Limited endpoint protection, Risk of lost/stolen devices	Offline data and credentials stored on devices are exposed

3.4 Identified Vulnerabilities

3.4.1 Network and Infrastructure Vulnerabilities

The current and planned network environment of Prismo Constructions (PVT) Ltd contains several important weaknesses at the infrastructure level. These vulnerabilities increase the likelihood of unauthorized access, lateral movement, and exposure of critical systems.

Lack of Network Segmentation

At present, Prismo Constructions (PVT) Ltd operates with a simple office network that does not separate different types of users or systems. Even in the proposed expanded architecture, segmentation is only logical and limited. Without strong separation between office users, the application/database environment, and remote access pathways, a compromise in one area could more easily affect other parts of the network. This increases the potential impact of malware infections or unauthorized access.

Limited Firewall Protection

The organization currently relies on basic internet connectivity without a properly configured enterprise firewall. Although a firewall is proposed in the new architecture, its absence in the existing environment means that incoming and outgoing traffic is not adequately filtered. This leaves the network more exposed to external scanning, unauthorized connection attempts, and opportunistic attacks.

Weak Remote Access Controls

Site Engineers require access to Prismo Constructions from construction sites. In the current environment, remote access is informal and largely uncontrolled. Even with the proposed design, remote access introduces risk if it is not carefully restricted, monitored, and protected through encryption and strong authentication. Weak remote access controls could allow attackers to exploit exposed entry points or compromised field devices.

Insecure Internet Exposure

Prismo Constructions will be accessible over the internet to support client access and remote site operations. If the application or supporting services are not properly protected, they may become directly reachable by external attackers. Insecure exposure increases the risk of brute-force attacks, exploitation of application vulnerabilities, and unauthorized attempts to access project data.

These network and infrastructure vulnerabilities are particularly significant because Prismo Constructions (PVT) Ltd is transitioning from a simple office setup to a system that must support remote users and external clients. Without adequate segmentation, filtering, and controlled access paths, the expanded environment could introduce new and more serious security risks.

3.4.2 Access Control and Authentication Vulnerabilities

Access control and authentication weaknesses represent a major area of risk for Prismo Constructions (PVT) Ltd, especially as the organization introduces multiple user roles and remote access.

Weak or Basic Authentication

Current practices rely mainly on simple username and password combinations. There is no evidence of strong password policies or centralized authentication management. When Prismo Constructions is implemented, weak authentication mechanisms could allow attackers to compromise user accounts through brute-force attacks, credential stuffing, or password guessing.

Absence of Multi-Factor Authentication

Multi-factor authentication (MFA) is not currently used. This is a significant weakness for remote users such as Site Engineers and Clients, who will access the system over the internet. Without MFA, a stolen or guessed password alone may be sufficient to gain unauthorized access to project information.

Insufficient Role-Based Access Control

In the present environment, formal role-based access control does not exist because there is no centralized system. Even after Prismo Constructions is introduced, poorly configured roles could result in users receiving excessive privileges. For example, a Site Engineer or Client might gain access to information beyond their assigned projects, increasing the risk of data exposure.

Shared or Weak Passwords

Small organizations frequently experience password reuse and weak password practices. If staff use simple or shared passwords across systems, a single compromised credential could provide access to Prismo Constructions and other business information. This risk is heightened during the transition period when new users are being added.

These weaknesses are critical because Prismo Constructions will contain sensitive project and client data. Weak authentication and poorly managed access rights could allow unauthorized individuals to view, modify, or misuse this information.

3.4.3 Data and Application Vulnerabilities

The way data is currently stored and handled, together with the planned digital platform, introduces several important vulnerabilities.

Unstructured Data Storage

Project information, documents, and progress updates are currently stored across individual laptops, email accounts, and messaging applications. This fragmented approach makes it difficult to apply consistent security controls and increases the likelihood of data loss, unauthorized sharing, or use of outdated information.

Insecure Handling of Progress Photos and Documents

Site photographs and project documents are often shared through WhatsApp or email. These channels are not designed for secure business document management. Once Prismo Constructions is implemented, improper configuration of file storage or weak access restrictions could still allow unauthorized viewing or downloading of sensitive files.

Lack of Encryption for Sensitive Data

There is limited evidence of encryption being applied to sensitive data at rest or in transit in the current environment. If Prismo Constructions does not enforce encryption for stored files and database content, and if communications are not properly protected, confidential project and client information could be exposed if intercepted or accessed unlawfully.

Weak Audit and Logging Mechanisms

The current environment lacks centralized logging and monitoring. Without proper audit trails, it becomes difficult to detect unauthorized access, investigate incidents, or establish accountability for actions performed within the system. Even after Prismo Constructions is introduced, insufficient logging would reduce the organization's ability to identify and respond to security events.

These data and application vulnerabilities are particularly important because Prismo Constructions is intended to become the central repository for project records, site evidence, and client communications. Any weakness in how this data is stored, transmitted, or monitored could have direct operational and reputational consequences for Prismo Constructions (PVT) Ltd .

3.4.4 Human and Process Vulnerabilities

Human and process-related weaknesses are significant in Prismo Constructions (PVT) Ltd because the organization is still transitioning from informal working methods to a more structured digital environment.

Heavy Reliance on Email and WhatsApp for Sensitive Communication

Project updates, progress photographs, documents, and client communications are frequently exchanged through email and WhatsApp. These tools are convenient but lack proper access control, audit trails, and data protection features. Sensitive information shared through these channels may be forwarded, stored on personal devices, or exposed if an account is compromised.

Limited Security Awareness

There is no evidence of formal information security awareness training within the organization. Staff may not fully understand the risks associated with weak passwords, unsafe file sharing, phishing messages, or the handling of confidential project data. Limited awareness increases the likelihood of accidental security incidents.

Informal Processes

Many operational processes are currently informal and undocumented. Task assignment, progress reporting, and approval handling often depend on individual habits rather than standardized procedures. Informal processes make it difficult to enforce security controls consistently and increase the chance of errors or omissions.

New Staff and Expanding Roles

As Prismo Constructions (PVT) Ltd expands into construction management, new Project Managers and Site Engineers are being appointed. New staff may be unfamiliar with expected security practices, and rapidly changing roles can lead to unclear responsibilities. This expansion period creates additional risk until secure processes and access controls are properly established.

These human and process vulnerabilities are important because technology controls alone cannot fully protect the organization if users continue insecure practices or if responsibilities remain unclear.

3.4.5 Physical and Endpoint Vulnerabilities

Physical and endpoint-related risks are especially relevant because Site Engineers will operate outside the office environment.

Use of Personal or Mobile Devices at Sites

Site Engineers are likely to use laptops or mobile devices at construction sites to submit progress logs and upload photographs. If personal or lightly managed devices are used, it becomes more difficult to enforce consistent security settings, updates, and access controls.

Limited Endpoint Protection

Current endpoint protection appears to be limited to basic antivirus software. Devices may not have full-disk encryption, centralized management, or strong access controls. This increases the risk that malware, unauthorized access, or data exposure could occur through endpoint devices.

Risk of Lost or Stolen Devices

Laptops and mobile devices used at construction sites are exposed to a higher risk of loss or theft due to the nature of field work. If a device containing project information, cached credentials, or photographs is lost and is not adequately protected, sensitive data could be accessed by unauthorized individuals.

These physical and endpoint vulnerabilities highlight the need for careful control of devices that connect to Prismo Constructions, particularly those used outside the relative security of the office environment.

3.5 Vulnerability Summary Table

The following table consolidates the key vulnerabilities identified in the current and planned environment of Prismo Constructions (PVT) Ltd. Each vulnerability is linked to the main assets affected and its potential impact.

Table 3.5.1: Consolidated Vulnerability Summary

No.	Vulnerability	Category	Affected Assets	Potential Impact
1	Lack of network segmentation	Network & Infrastructure	Prismo Constructions system, Project data, Database	Higher chance of lateral movement and wider impact from a single compromise
2	Limited firewall protection	Network & Infrastructure	Application server, Database, Office network	Increased exposure to external attacks and unauthorized connection attempts
3	Weak remote access controls	Network & Infrastructure	Site Engineer access, Project data, Progress photos	Unauthorized remote access and possible interception of data in transit
4	Insecure internet exposure	Network & Infrastructure	Prismo Constructions application, Client data	Greater risk of external scanning, brute-force attacks, and exploitation
5	Weak or basic authentication	Access Control & Authentication	User accounts, Project data, Client information	Account compromise and unauthorized access to sensitive information
6	Absence of multi-factor authentication	Access Control & Authentication	Remote users, Client accounts, Credentials	Stolen passwords alone may be sufficient to gain access
7	Insufficient role-based access control	Access Control & Authentication	Project data, Documents, Progress logs	Users may access information beyond their responsibilities
8	Shared or weak passwords	Access Control & Authentication	User accounts, System access	Credential misuse and easier unauthorized entry
9	Unstructured data storage	Data & Application	Project records, Documents, Progress information	Data loss, version confusion, and difficulty applying consistent protection

10	Insecure handling of progress photos and documents	Data & Application	Photos, Client documents, Project files	Unauthorized sharing, leakage, or loss of sensitive project evidence
11	Lack of encryption for sensitive data	Data & Application	Database content, Files, Credentials	Exposure of confidential information if intercepted or accessed unlawfully
12	Weak audit and logging mechanisms	Data & Application	System logs, User activity records	Reduced ability to detect, investigate, and respond to security incidents
13	Heavy reliance on email and WhatsApp	Human & Process	Project updates, Photos, Client communications	Uncontrolled sharing and limited traceability of sensitive information
14	Limited security awareness	Human & Process	All information assets	Higher likelihood of accidental incidents and successful social engineering
15	Informal processes	Human & Process	Task records, Approvals, Progress reporting	Inconsistent security practices and reduced accountability
16	New staff and expanding roles	Human & Process	Access rights, Project data	Unclear responsibilities and increased risk during organizational transition
17	Use of personal/mobile devices at sites	Physical & Endpoint	Progress data, Photos, Credentials	Weaker control over devices that connect to Prismo Constructions
18	Limited endpoint protection	Physical & Endpoint	Laptops, Mobile devices	Greater risk of malware infection and unauthorized access via endpoints
19	Risk of lost or stolen devices	Physical & Endpoint	Stored files, Cached data, User credentials	Possible exposure of sensitive information if devices are not adequately protected

Table provides a consolidated view of the major vulnerabilities identified across network infrastructure, access control, data handling, human processes, and endpoint usage. These weaknesses affect critical assets such as the Prismo Constructions system, project data, progress photographs, client documents, and user credentials. The potential impacts range from unauthorized access and data leakage to reduced accountability and operational disruption. This summary forms the basis for the formal risk assessment presented in Task 4.

3.6 Impact of Identified Vulnerabilities

The vulnerabilities identified in the previous section have the potential to affect the confidentiality, integrity, and availability of Prismo Constructions (PVT) Ltd information and systems. These impacts are particularly significant because the organization is implementing Prismo Constructions as a central platform for project management and client interaction.

Impact on Confidentiality

Several vulnerabilities directly threaten the confidentiality of sensitive information. Weak authentication, insufficient access control, insecure handling of documents and photographs, and the use of informal communication channels such as email and WhatsApp increase the risk of unauthorized disclosure. Project data, client information, progress photographs, and approval records could be accessed by individuals who do not have a legitimate need to view them. Remote access from construction sites and the possible loss of devices further increase the likelihood of confidential data exposure.

Impact on Integrity

Integrity risks arise where information can be modified without proper authorization or control. Insufficient role-based access control, weak authentication, unstructured data storage, and limited logging reduce the organization's ability to ensure that project records remain accurate and trustworthy. If progress logs, task statuses, or documents are changed incorrectly or maliciously, management and clients may make decisions based on unreliable information. The absence of strong audit mechanisms also makes it harder to detect and correct integrity issues.

Impact on Availability

Availability may be affected by weaknesses in infrastructure protection, endpoint security, and remote access controls. Limited firewall protection, exposure of systems to the internet, malware risks on poorly protected devices, and dependence on unstable remote connections could disrupt access to Prismo Constructions. If Project Managers or Site Engineers are unable to access the system when needed, daily progress tracking, task coordination, and client communication may be delayed.

Business Impact on Prismo Constructions

From a business perspective, these impacts could undermine the organization's expansion into construction management. Loss of confidentiality may damage client trust and harm the company's reputation. Integrity problems could lead to project delays, disputes, or incorrect reporting. Availability issues may reduce operational efficiency and weaken coordination between the office and construction sites. In a competitive industry, such weaknesses could limit Prismo Constructions (PVT) Ltd ability to deliver professional, reliable, and scalable project management services.

Overall, the identified vulnerabilities are not only technical concerns but also business risks. Addressing them is essential to protect sensitive information, maintain reliable operations, and support the successful adoption of Prismo Constructions.

Table 3.6.1: CIA Impact Summary of Identified Vulnerabilities

CIA Component	Level of Impact	Key Contributing Vulnerabilities	Description of Impact
Confidentiality	High	Weak authentication, Absence of MFA, Insecure handling of photos & documents, Lack of encryption, Heavy use of email/WhatsApp, Lost/stolen devices, Insufficient RBAC	Unauthorized individuals may gain access to project data, client information, progress photos, and documents
Integrity	High	Insufficient role-based access control, Weak authentication, Unstructured data storage, Weak audit and logging, Informal processes	Project records, progress logs, and documents may be modified incorrectly or without authorization, reducing trust in the information
Availability	Medium – High	Limited firewall protection, Insecure internet exposure, Weak remote access controls, Limited endpoint protection, Use of personal devices at sites	Users (especially Site Engineers and Project Managers) may face disruption when accessing Prismo Constructions, affecting daily operations

3.7 Summary of Task 3

Task 3 has identified the main security vulnerabilities present in Prismo Constructions (PVT) Ltd current environment and those associated with the planned implementation of Prismo Constructions. The analysis shows that the organization faces weaknesses across several areas, including network infrastructure, access control and authentication, data and application protection, human and process practices, and physical or endpoint security.

Key findings indicate that the current reliance on informal communication tools, limited security controls, and unstructured data handling creates significant exposure. The introduction of Prismo Constructions and remote access for Site Engineers and Clients further expands the attack surface if strong authentication, access control, segmentation, and data protection measures are not properly implemented. Critical assets such as project data, progress photographs, client documents, and user credentials are particularly at risk.

These identified vulnerabilities provide the essential input for the formal risk assessment in Task 4. Each vulnerability will be examined in relation to relevant threats, the likelihood of exploitation, and the potential business impact. This will allow risks to be prioritized and appropriate treatment measures to be recommended, ensuring that the most significant issues are addressed as Prismo Constructions expands its digital operations.

4. Vulnerability and Risk Assessment

4.1 Introduction

This section presents the formal vulnerability and risk assessment for Prismo Constructions (PVT) Ltd in relation to its current environment and the planned implementation of the Prismo Constructions platform. The purpose of this assessment is to evaluate the identified vulnerabilities in terms of the threats that could exploit them, the likelihood of occurrence, and the potential business impact. This enables the prioritization of risks and provides a clear basis for selecting appropriate security controls.

The assessment builds directly on the findings of Task 3, where key vulnerabilities were identified across network infrastructure, access control and authentication, data and application protection, human and process practices, and physical or endpoint security. These vulnerabilities were shown to affect critical assets such as the Prismo Constructions system, project data, progress photographs, client documents, and user credentials.

The scope of this risk assessment covers the most significant risks associated with both the existing limited IT environment and the proposed expanded network supporting Prismo Constructions. Particular attention is given to risks arising from remote access by Site Engineers, external access by Clients, weak authentication, insecure data handling, and the organization's relatively low security maturity during its expansion into construction management.

The risk assessment follows a structured qualitative approach aligned with common information security practice and consistent with the principles of ISO/IEC 27001. Each selected risk is examined in terms of the related vulnerability, applicable threat, impact on confidentiality, integrity and availability, estimated likelihood, overall impact, and resulting risk level. Existing controls are noted where relevant, and recommended controls are identified to support later risk treatment activities.

This section provides the analytical foundation for Task 5, where the prioritised risks will be aligned with ISO/IEC 27001 controls and suitable treatment measures will be proposed.

4.2 Risk Assessment Methodology

The risk assessment for Prismo Constructions (PVT) Ltd follows a structured qualitative approach that is practical for a small organization and consistent with the principles of ISO/IEC 27001. This approach allows risks to be evaluated systematically using clearly defined criteria for likelihood and impact.

Risk Assessment Approach Used

The assessment is based on the relationship between identified vulnerabilities, relevant threats, and the potential consequences for critical assets. For each significant risk, the following elements are considered:

- The asset or system affected
- The vulnerability that could be exploited
- The related threat
- The impact on Confidentiality, Integrity, and Availability
- The likelihood of the risk materializing
- The overall business impact

- The resulting risk level
- Existing controls (if any)
- Recommended controls

This method provides a clear and repeatable way to compare and prioritize risks.

Criteria for Likelihood

Likelihood is assessed using a three-level scale:

Table 4.2.1: Criteria for Likelihood

Level	Description
High	The threat is expected to occur frequently or is already a realistic concern given current practices and exposure
Medium	The threat may occur occasionally under present conditions
Low	The threat is unlikely to occur under normal circumstances

Criteria for Impact

Impact is assessed based on the potential effect on the organization if the risk materializes:

Table 4.2.0.2: Criteria for Impact

Level	Description
High	Significant damage to confidentiality, integrity, or availability, with serious business, client, or reputational consequences
Medium	Moderate disruption or limited exposure of information, with noticeable operational impact
Low	Minor or limited effect on operations or information

Risk Level Calculation Method

The overall risk level is determined by combining Likelihood and Impact using the following simple risk matrix approach:

- High Likelihood + High Impact = **High / Critical Risk**
- High Likelihood + Medium Impact = **High Risk**
- Medium Likelihood + High Impact = **High Risk**
- Medium Likelihood + Medium Impact = **Medium Risk**
- Low Likelihood or Low Impact combinations = **Low to Medium Risk**

This provides a practical basis for prioritising risks that require immediate attention.

Reference to ISO/IEC 27001 Aligned Approach

The methodology is aligned with the risk assessment principles of ISO/IEC 27001, which require organizations to identify risks to information assets, assess their likelihood and consequences, and determine appropriate treatment. While a full formal ISMS is not being implemented in this academic project, the approach used here supports later alignment with ISO/IEC 27001 controls and the use of the provided toolkit in Task 5.

This methodology ensures that the risk assessment remains structured, transparent, and suitable for the operational context of Prismo Constructions (PVT) Ltd.

4.3 Risk Assessment Criteria

Clear assessment criteria are required to ensure that risks are evaluated consistently. The following scales and definitions are used in this assessment.

Table 4.3.1: Likelihood Scale

Likelihood	Score	Description
Low	1	The threat is unlikely to occur under normal conditions
Medium	2	The threat may occur occasionally given current practices and exposure
High	3	The threat is expected to occur frequently or is already a realistic concern

Table 4.3.2: Impact Scale

Impact	Score	Description
Low	1	Limited effect on operations or information; impact can be managed easily
Medium	2	Noticeable operational disruption or moderate exposure of sensitive information
High	3	Significant damage to confidentiality, integrity, or availability, with serious business or reputational consequences

Table 4.3.3: Risk Matrix

Likelihood ↓ / Impact →	Low (1)	Medium (2)	High (3)
High (3)	Medium	High	Critical
Medium (2)	Low	Medium	High
Low (1)	Low	Low	Medium

Table 4.3.4: Risk Level Definitions

Risk Level	Definition
Critical	Immediate attention required. The risk could cause severe damage to project operations, client trust, or sensitive data. Treatment should be prioritised urgently.
High	Significant risk that should be addressed as a priority. Strong controls are needed to reduce likelihood or impact.
Medium	Moderate risk that should be managed within a planned timeframe. Existing controls may be partially effective but require improvement.
Low	Acceptable or minor risk under current conditions. Monitoring is usually sufficient unless circumstances change.

These criteria provide a consistent basis for evaluating and prioritising the risks identified in the next section.

4.4 Detailed Risk Assessment

The following table presents the most significant risks identified for Prismo Constructions (PVT) Ltd in relation to the current environment and the planned Prismo Constructions system. Risks have been selected based on the vulnerabilities identified in Task 3 and prioritised according to their potential business impact.

Table 4.4.1: Detailed Risk Assessment – Prismo Constructions

Risk ID	Asset / System	Vulnerability	Threat	CIA Impact	Likelihood	Impact	Risk Level	Existing Controls	Recommended Controls
R01	User Accounts & Prismo Constructions Access	Weak or basic authentication; Absence of MFA	Credential theft / Brute-force attack	C, I, A	High	High	Critical	Simple passwords only	Enforce strong password policy + Multi-Factor Authentication
R02	Project Data & Client Information	Insufficient role-based access control	Unauthorized access / Privilege misuse	C, I	High	High	Critical	Limited / informal access control	Implement strict Role-Based Access Control (RBAC)

R03	Progress Photos & Documents	Insecure handling of photos and documents	Data leakage / Unauthorized sharing	C	High	High	Critical	Shared via email & Whats App	Centralized secure storage + access-controlled sharing
R04	Remote Access (Site Engineers)	Weak remote access controls	Unauthorized remote access / Interception	C, I, A	High	High	Critical	Informal remote usage	Secure HTTPS access + strong authentication + session control
R05	Prismo Constructions Application & Database	Limited firewall protection ; Insecure exposure	External attack / System compromise	C, I, A	Medium	High	High	Basic internet connection only	Properly configured firewall + restricted external access
R06	Laptops & Mobile Devices	Risk of lost or stolen devices; Limited endpoint protection	Device loss / Data exposure	C, I	Medium	High	High	Basic antiviruses	Endpoint protection + encryption + remote wipe capability
R07	Project Data & Communications	Heavy reliance on email and WhatsApp	Information leakage / Lack of accountability	C, I	High	Medium	High	Email and Whats App commonly used	Move sensitive communication into Prismo Constructions
R08	Sensitive Data (Database & Files)	Lack of encryption for sensitive data	Data interception / Unauthorized disclosure	C	Medium	High	High	Limited encryption	Encrypt data in transit (HTTPS) and at rest where feasible

R09	System Activity & Incident Detection	Weak audit and logging mechanisms	Undetected unauthorized activity	I, A	Medium	Medium	Medium	Minimal logging	Enable centralized logging and basic monitoring
R10	All Information Assets	Limited security awareness	Phishing / Accidental data exposure	C, I, A	Medium	Medium	Medium	No formal awareness program	Conduct basic security awareness for staff
R11	Network Environment	Lack of network segmentation	Lateral movement after compromise	C, I, A	Medium	Medium	Medium	Flat / simple network	Apply practical network segmentation
R12	Project Records & Progress Data	Unstructured data storage	Data loss / Version confusion	I, A	Medium	Medium	Medium	Data stored on individual devices	Centralize data storage within Prismo Constructions

Notes:

- **CIA Impact:** C = Confidentiality, I = Integrity, A = Availability
- Risk Levels were determined using the criteria defined in Section 4.3
- Critical and High risks should be treated as priority items in the risk treatment plan

This detailed risk assessment provides a clear prioritisation of the most important security issues facing Prismo Constructions (PVT) Ltd as it implements Prismo Constructions and expands into construction management.

4.5 Risk Summary by Level

The risks identified in the detailed assessment can be grouped according to their overall risk level. This summary helps Prismo Constructions prioritise security improvements effectively.

Critical Risks

These risks require immediate attention because they combine high likelihood with high business impact:

- **R01** – Weak authentication and absence of multi-factor authentication
- **R02** – Insufficient role-based access control

- **R03** – Insecure handling of progress photos and documents
- **R04** – Weak remote access controls for Site Engineers

These risks directly threaten the confidentiality and integrity of project and client information and could seriously undermine trust in Prismo Constructions.

High Risks

These risks are significant and should be addressed as a priority:

- **R05** – Limited firewall protection and insecure internet exposure
- **R06** – Lost or stolen devices with limited endpoint protection
- **R07** – Heavy reliance on email and WhatsApp for sensitive communication
- **R08** – Lack of encryption for sensitive data

These risks could lead to data exposure, unauthorized access, or operational disruption if left untreated.

Medium Risks

These risks should be managed within a planned timeframe:

- **R09** – Weak audit and logging mechanisms
- **R10** – Limited security awareness
- **R11** – Lack of network segmentation
- **R12** – Unstructured data storage

Although less urgent than Critical and High risks, these issues still weaken overall security and accountability.

Low Risks

No risks in the current assessment were classified as Low. This reflects the organization's current limited security maturity and the increased exposure created by remote access and digital transformation.

Table 4.0.5.1: Priority Ranking of Risks

Priority	Risk ID	Risk Description	Risk Level
1	R01	Weak authentication / No MFA	Critical
2	R02	Insufficient role-based access control	Critical
3	R03	Insecure handling of photos and documents	Critical
4	R04	Weak remote access controls	Critical
5	R05	Limited firewall protection / Insecure exposure	High
6	R06	Lost or stolen devices / Weak endpoint protection	High

7	R07	Heavy reliance on email and WhatsApp	High
8	R08	Lack of encryption for sensitive data	High
9	R09	Weak audit and logging	Medium
10	R10	Limited security awareness	Medium
11	R11	Lack of network segmentation	Medium
12	R12	Unstructured data storage	Medium

This prioritisation provides a clear order for risk treatment and will support the control recommendations and ISO/IEC 27001 alignment presented in Task 5.

4.6 Key Risk Insights

The risk assessment highlights several important insights for Prismo Constructions (PVT) Ltd as it expands into construction management and implements Prismo Constructions.

Most Critical Risks

The highest priority risks are related to weak authentication, insufficient role-based access control, insecure handling of progress photos and documents, and weak remote access controls. These risks are rated Critical because they combine a realistic likelihood of occurrence with the potential for serious damage to confidentiality and integrity. If these issues are not addressed, unauthorized users could gain access to sensitive project and client information.

Risks Related to Remote Access and Expansion

The organization's expansion significantly increases its exposure. Site Engineers will access the system from construction sites, and Clients will connect over the internet. Weak remote access controls, limited endpoint protection, and the possible loss of devices create a clear set of risks linked to this new operating model. These risks did not exist at the same level when the organization relied mainly on office-based consultancy work.

Risks Related to Data Protection and Authentication

A major cluster of risks centres on how data is accessed and protected. Weak passwords, the absence of multi-factor authentication, lack of encryption, unstructured data storage, and continued use of email and WhatsApp all reduce the organization's ability to keep project data confidential and trustworthy. Because Prismo Constructions is intended to become the central system for project information, weaknesses in authentication and data protection are especially significant.

Business Implications of the Highest Risks

If the Critical and High risks are not treated effectively, Prismo Constructions (PVT) Ltd could face data leakage, loss of client trust, incorrect project reporting, and disruption to daily coordination between the office and construction sites. These outcomes would weaken the organization's ability to deliver professional construction management services and could damage its reputation during an important growth phase.

4.7 Summary of Task 4

Task 4 has evaluated the major vulnerabilities identified earlier and translated them into prioritised information security risks. The assessment shows that Prismo Constructions (PVT) Ltd currently faces several Critical and High risks, particularly in the areas of authentication, access control, remote access, and protection of project-related data.

The most serious risks are linked to the organization's low security maturity and the increased exposure created by implementing Prismo Constructions and supporting remote users. Medium-level risks related to logging, awareness, segmentation, and data storage also require attention as part of a structured improvement plan.

These results provide a clear foundation for Task 5. The prioritised risks will be used to identify suitable ISO/IEC 27001 aligned controls, complete the relevant toolkit components, and recommend practical risk treatment measures appropriate for Prismo Constructions' size and stage of digital transformation.

5. ISO/IEC 27001 Alignment and Risk Treatment

5.1 Introduction

This section aligns the prioritised information security risks identified for Prismo Constructions (PVT) Ltd with the principles and control guidance of ISO/IEC 27001. The purpose of this alignment is to translate the results of the risk assessment into a structured set of security controls and treatment actions that are practical for the organization and consistent with recognised information security management practice.

Task 4 identified several Critical and High risks, particularly in the areas of authentication, access control, remote access, protection of project data and photographs, and endpoint security. These risks arise from the organization's current limited security maturity and from the increased exposure created by implementing Prismo Constructions and supporting remote users. Without a structured treatment approach, these risks could undermine the confidentiality, integrity, and availability of project and client information.

ISO/IEC 27001 is important in this context because it provides an internationally recognised framework for managing information security risks through appropriate policies, processes, and controls. Although Prismo Constructions (PVT) Ltd does not seek formal certification at this stage, aligning the recommended controls with ISO/IEC 27001 helps ensure that the proposed security measures are systematic, justifiable, and suitable for supporting the organization's digital transformation.

The scope of this section includes the review of critical assets, the presentation of an ISO-aligned risk register perspective, the identification of control gaps, the selection of relevant Annex A controls, and the development of a practical risk treatment plan. The provided ISO 27001 Toolkit is used to support asset registration, risk recording, and control mapping. The focus remains on controls that are realistic for a small organization expanding into construction management and implementing a new web-based project management platform.

5.2 Overview of ISO/IEC 27001 Relevance

ISO/IEC 27001 is the international standard for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS). It provides a structured framework that helps organizations identify information security risks and apply appropriate controls to protect the confidentiality, integrity, and availability of information. The standard is supported by a reference set of security controls defined in Annex A, which cover areas such as access control, cryptography, operations security, communications security, and supplier relationships.

ISO/IEC 27001 is relevant to Prismo Constructions because the organization is moving from informal, manual processes to a centralized digital platform that will store and process sensitive project and client information. As Prismo Constructions becomes a core business system, Prismo will increasingly depend on secure authentication, controlled access, protected data storage, and reliable system availability. Aligning with ISO/IEC 27001 helps the organization address these requirements in a systematic way rather than applying security controls in an ad hoc manner.

The standard supports risk treatment by linking identified risks to suitable controls and by encouraging a clear decision process for how each risk should be handled. Through this approach, risks may be mitigated through controls, accepted under defined conditions, transferred, or avoided. This structured method is particularly useful for Prismo Constructions (PVT) Ltd, as it allows the organization to prioritise Critical and High risks while selecting controls that are realistic for its size, resources, and stage of digital expansion.

In this assessment, the provided ISO 27001 Toolkit is used to support the practical application of the standard. The toolkit assists with recording information assets, documenting risks, reviewing control status, and identifying gaps. Although a full formal ISMS is not being implemented within the scope of this academic project, the toolkit enables a meaningful and structured alignment between the prioritised risks and relevant ISO/IEC 27001 controls.

5.3 Information Asset Register and Valuation

A clear understanding of information assets is essential for effective risk treatment. In line with ISO/IEC 27001 principles, the critical information assets related to Prismo Constructions and Prismo Constructions (PVT) Ltd expanded operations have been identified, classified, and valued.

Summary of Critical Information Assets

The most important assets identified for protection include:

- Prismo Constructions Web Application
- Project Data and Records
- Progress Photographs and Site Images
- Client Documents and Approval Records
- User Accounts and Credentials
- System Logs and Audit Trails
- Prismo Constructions Database
- Endpoint devices used by Project Managers and Site Engineers

These assets are central to daily project operations, client communication, and management visibility.

Each critical asset was assessed against the three core information security properties:

Table 5.3.1: Asset Classification (Confidentiality, Integrity, Availability)

Asset	Confidentiality	Integrity	Availability
Prismo Constructions Web Application	High	High	High
Project Data and Records	High	High	High
Progress Photographs & Site Images	High	Medium	Medium
Client Documents & Approvals	High	High	Medium
User Accounts & Credentials	High	High	High
System Logs & Audit Trails	Medium	High	Medium
Prismo Constructions Database	High	High	High
Staff Laptops / Site Devices	High	Medium	High

Asset Valuation Results

Assets were valued using a simple High / Medium / Low scale based on their importance to business operations and the potential damage if compromised. Most core Prismo Constructions -related assets were rated **High** in value because their compromise could lead to loss of client trust, incorrect project decisions, operational disruption, or unauthorized disclosure of sensitive information. Progress photographs and logs were also rated highly due to their importance as project evidence.

Link to the Completed Asset Register (Toolkit)

The detailed asset information has been recorded in the ISO 27001 Toolkit Asset Register prepared for Prismo Constructions (PVT) Ltd. This register includes asset ownership, classification, and valuation details and provides the formal reference for the risk assessment and control selection activities in this section.

By identifying and valuing these assets, Prismo Constructions (PVT) Ltd can focus security controls on the information and systems that matter most to its construction management operations and digital transformation.

5.4 Risk Register (ISO 27001 Aligned)

The prioritised risks identified in Task 4 have been structured in a format consistent with ISO/IEC 27001 risk registration practice. This allows the risks to be clearly linked to assets, vulnerabilities, threats, and treatment decisions.

Summary of Prioritised Risks from Task 4

The risk assessment identified twelve significant risks. The most important were:

- **Critical Risks:** Weak authentication / absence of MFA, insufficient role-based access control, insecure handling of progress photos and documents, and weak remote access controls.
- **High Risks:** Limited firewall protection, lost or stolen devices, continued reliance on email and WhatsApp, and lack of encryption for sensitive data.
- **Medium Risks:** Weak logging, limited security awareness, lack of network segmentation, and unstructured data storage.

These risks primarily affect the Prismo Constructions system, project data, client information, progress photographs, user credentials, and endpoint devices.

Mapping into ISO 27001 Risk Register Format

For ISO/IEC 27001 alignment, each prioritised risk is recorded using the following key fields:

Field	Description
Asset	The information asset or system affected
Vulnerability	The weakness that could be exploited
Threat	The source or event that could exploit the vulnerability
Likelihood	Estimated chance of occurrence
Impact	Potential business and CIA impact

Risk Level	Overall risk rating (Critical / High / Medium)
Existing Controls	Controls currently in place
Recommended Controls	Controls proposed to reduce the risk

This structure supports clear risk ownership, treatment planning, and later review.

Reference to the Completed Risk Register (Toolkit)

The detailed risk entries have been prepared in line with the ISO 27001 Toolkit Risk Register format. The register consolidates the Critical, High, and Medium risks identified for Prismo Constructions and provides the formal basis for selecting Annex A controls and defining treatment actions in the following sections.

By maintaining the risks in an ISO-aligned register, Prismo Constructions can manage information security risks in a structured and repeatable manner as Prismo Constructions is implemented and the organization continues its expansion into construction management.

5.5 Control Selection and Gap Analysis

Effective risk treatment requires a clear understanding of the controls already in place, the gaps that exist, and the ISO/IEC 27001 controls that can be applied to reduce the prioritised risks.

Existing Controls Currently in Place

Prismo Constructions (PVT) Ltd currently operates with a limited set of basic controls. These include:

- Password-based login on staff computers
- Basic antivirus software on some devices
- Standard internet connectivity through an ISP
- Informal access to email and messaging tools
- Limited manual oversight of project communication

These controls provide only minimal protection and are not sufficient for a multi-user digital project management environment.

Control Gaps Identified

Several important control gaps were identified through the risk assessment:

- No multi-factor authentication
- No formal role-based access control
- Limited or no firewall-based network protection
- No structured remote access security
- No centralized secure storage for photos and documents
- Limited encryption of sensitive data
- Weak or missing audit logging

- No formal security awareness practices
- Limited endpoint protection for site-based devices
- No clear network segmentation

These gaps leave the organization exposed to unauthorized access, data leakage, and limited incident visibility.

Selection of Appropriate ISO/IEC 27001 Annex A Controls

Based on the prioritised risks and identified gaps, the following Annex A control areas are particularly relevant for Prismo Constructions (PVT) Ltd:

Control Area	Example Annex A Focus	Relevance to Prismo Constructions
Access Control	User access management, privileged access	Critical for authentication and role separation
Cryptography	Encryption of sensitive data	Protects project data, credentials, and files
Operations Security	Logging, malware protection, backup	Improves detection and resilience
Communications Security	Secure transfer of information	Important for remote and client access
System Acquisition & Development	Secure application configuration	Relevant to ConstructFlow implementation
Supplier / Cloud Considerations	Protection of externally hosted services	Relevant if cloud hosting is used
Human Resource Security	Awareness and responsibilities	Supports safer staff behaviour
Asset Management	Inventory and classification	Already supported through the Asset Register

Mapping of Recommended Controls to Identified Risks

Risk ID	Key Risk	Recommended Control Focus	Related ISO/IEC 27001 Area
R01	Weak authentication / No MFA	Strong authentication and MFA	Access Control
R02	Insufficient role-based access control	Formal RBAC and least privilege	Access Control
R03	Insecure handling of photos and documents	Secure storage and controlled sharing	Asset Management / Access Control

R04	Weak remote access controls	Secure remote access and encrypted connections	Communications Security
R05	Limited firewall protection	Firewall and restricted external exposure	Network / Operations Security
R06	Lost or stolen devices	Endpoint protection and device controls	Operations Security
R07	Heavy reliance on email and WhatsApp	Move sensitive communication into Prismo Constructions	Access Control / Communications
R08	Lack of encryption	Encryption in transit and at rest where feasible	Cryptography
R09	Weak logging	Enable audit logging and monitoring	Operations Security
R10	Limited security awareness	Basic security awareness activities	Human Resource Security

This control selection focuses on practical measures that directly address the Critical and High risks facing Prismo Constructions (PVT) Ltd. The chosen controls provide a realistic starting point for improving security as Prismo Constructions is implemented, while remaining aligned with ISO/IEC 27001 guidance.

5.6 Statement of Applicability (High-Level)

The Statement of Applicability (SoA) identifies which ISO/IEC 27001 Annex A controls are relevant to Prismo Constructions (PVT) Ltd at the current stage of digital transformation. Because the organization is small and is implementing Prismo Constructions as a new platform, the SoA focuses on practical and high-priority controls rather than a full enterprise-wide implementation.

Overview of Selected Controls

The controls selected as applicable are those that directly address the Critical and High risks identified in Task 4. These include controls related to:

- Access control and user authentication
- Role-based access management
- Secure remote access
- Protection of stored and transmitted data
- Logging and monitoring
- Malware and endpoint protection
- Information classification and asset management
- Security awareness
- Secure system configuration for Prismo Constructions

These controls form the core set required to protect project data, client information, progress photographs, and user credentials.

Justification for Including Key Controls

Key controls were included for the following reasons:

- **Access control and authentication controls** are essential because weak login security and insufficient role separation were identified as Critical risks.
- **Cryptographic and secure communication controls** are required to protect remote access by Site Engineers and external access by Clients.
- **Operations security controls**, including logging and malware protection, are needed to improve visibility and reduce endpoint-related risks.
- **Asset management and classification controls** support structured handling of project data and documents.
- **Human resource related awareness controls** are necessary because limited security awareness was identified as a contributing risk factor.

These controls are realistic for Prismo Constructions (PVT) Ltd and can be implemented gradually as Prismo Constructions is deployed.

Controls Considered Not Applicable

Some Annex A controls are not considered immediately applicable or are deferred due to the organization's current size and scope. Examples include:

- Advanced supplier relationship security processes beyond basic hosting considerations
- Complex physical security controls for large data centres (not currently relevant)
- Extensive formal ISMS documentation and audit processes associated with full certification
- Highly specialized industrial control system security controls (not applicable to this environment)

These controls may become relevant later if the organization grows significantly or seeks formal ISO/IEC 27001 certification.

Reference to SoA / Controls Status from the Toolkit

The high-level applicability decisions described in this section are supported by the ISO 27001 Toolkit materials, including the controls status and gap-related worksheets. These toolkit outputs provide a structured reference for tracking which controls are selected, which gaps exist, and how the selected controls relate to the prioritised risks of Prismo Constructions.

This high-level Statement of Applicability ensures that control selection remains focused, justified, and appropriate for the organization's current operational and security needs.

5.7 Risk Treatment Plan

The risk treatment plan defines how Prismo Constructions (PVT) Ltd should respond to the prioritised risks identified in Task 4. The objective is to reduce Critical and High risks to an acceptable level through practical and realistic controls.

Treatment Options Selected

For this assessment, the primary treatment option selected is **Mitigate** through the application of appropriate security controls. This approach is suitable because most of the identified risks can be reduced by improving authentication, access control, data protection, remote access security, and endpoint protection.

- **Mitigate / Apply Control** – Selected for all Critical and High risks
- **Accept** – Not selected for Critical or High risks at this stage
- **Transfer** – Not currently applicable (for example, through insurance or outsourcing of security operations)
- **Avoid** – Not selected, as Prismo Constructions is required for business expansion

Treatment actions are prioritised based on risk level:

Table 5.7.1: Priority of Treatment Actions

Priority	Risk Level	Action Focus
Immediate	Critical	Authentication, access control, secure handling of photos/documents, remote access protection
Short-term	High	Firewall protection, endpoint security, encryption, reduced reliance on email/WhatsApp
Medium-term	Medium	Logging and monitoring, security awareness, network segmentation, centralized data storage

Table 5.7.0.2: Recommended Controls for Critical and High Risks

Risk ID	Risk Description	Recommended Treatment Controls	Expected Result
R01	Weak authentication / No MFA	Strong password policy + Multi-Factor Authentication	Reduced account compromise risk
R02	Insufficient role-based access control	Formal RBAC with least privilege	Limited unauthorized access
R03	Insecure handling of photos and documents	Centralized secure storage + controlled sharing in Prismo Constructions	Reduced data leakage
R04	Weak remote access controls	Secure HTTPS access + strong authentication + session controls	Safer remote connectivity
R05	Limited firewall protection	Configured firewall + restricted external exposure	Reduced external attack surface
R06	Lost or stolen devices	Endpoint protection + device authentication + data minimization	Lower impact of device loss

R07	Heavy reliance on email and WhatsApp	Shift sensitive communication into Prismo Constructions	Improved control and accountability
R08	Lack of encryption	HTTPS for data in transit + encryption of sensitive stored data where feasible	Improved confidentiality

If the recommended controls are implemented effectively, the residual risk levels are expected to reduce as follows:

Table 5.7.0.3: Expected Residual Risk After Treatment

Original Risk Level	Expected Residual Risk	Reason
Critical	Medium	Strong authentication, RBAC, and secure access significantly reduce exposure
High	Low – Medium	Firewall, endpoint controls, encryption, and process changes reduce likelihood and impact
Medium	Low	Supporting controls improve visibility and consistency

Residual risk cannot be reduced to zero. However, after treatment, the remaining risk is expected to fall within a manageable level for a small organization implementing a new digital platform. Continued monitoring and gradual improvement will be required as Prismo Constructions becomes fully operational.

This risk treatment plan provides Prismo Constructions (PVT) Ltd with a clear, prioritised path for improving information security in line with ISO/IEC 27001 principles while remaining practical for its current size and resources.

5.8 Roles and Responsibilities

Clear roles and responsibilities are essential for the successful implementation and ongoing management of the recommended security controls. Because Prismo Constructions (PVT) Ltd is a small organization, the allocation of security-related duties must remain practical and realistic.

Table 5.8.1: Key Roles Related to Security Control Implementation

Role	Main Security-Related Responsibility
CEO	Provides overall authority, approves major security decisions, and ensures business alignment
Project Manager	Oversees day-to-day access control within Prismo Constructions, monitors project-related data protection, and coordinates with users
System / IT Support (internal or external)	Implements technical controls (authentication, firewall rules, backups, logging, endpoint protection)

Site Engineer	Follows secure usage practices when accessing the system from construction sites
Client (Project Owner)	Uses the system responsibly and protects their own login credentials
Administrative Officer	Supports basic administrative tasks related to user coordination and document handling

Table 4.8.2: RACI Overview (Simplified)

Activity	CEO	Project Manager	IT Support	Site Engineer	Client
Approve security policies / major controls	A	C	C	I	I
Implement technical security controls	I	C	R/A	I	I
Manage user access and roles in Prismo Constructions	I	R/A	C	I	I
Secure handling of progress data and photos	I	A	C	R	I
Follow secure remote access practices	I	C	C	R	R
Monitor logs and report incidents	I	C	R/A	I	I
Security awareness and good practices	A	R	C	R	I

Legend:

R = Responsible, **A** = Accountable, **C** = Consulted, **I** = Informed

Practical Responsibilities for a Small Organization

Given the limited size of Prismo Constructions, it is not realistic to create many specialized security positions. Instead, responsibilities should be distributed as follows:

- The **CEO** retains final accountability for major security decisions and resource approval.
- The **Project Manager** acts as the main operational owner of access control and data handling practices within Prismo Constructions.
- Technical implementation and maintenance of controls (firewall, authentication settings, backups, logging) should be handled by an assigned **IT support person** or a trusted external service provider.
- **Site Engineers** and **Clients** are responsible for following secure usage rules, protecting their credentials, and reporting problems promptly.
- Formal security tasks should remain simple, documented, and reviewed periodically rather than becoming overly bureaucratic.

This practical distribution of responsibilities supports the implementation of the recommended controls while remaining suitable for a small organization that is still expanding its digital capabilities.

5.9 Summary of Task 5

Task 5 has aligned the prioritised information security risks of Prismo Constructions (PVT) Ltd with the principles and control guidance of ISO/IEC 27001. Using the provided toolkit, critical information assets were registered and valued, risks were structured in an ISO-aligned format, control gaps were identified, and a practical set of Annex A controls was selected. A high-level Statement of Applicability and a prioritised risk treatment plan were also developed to guide implementation.

The key outcome of this alignment is a clear and realistic security improvement path that focuses on the most important weaknesses first. Critical and High risks related to authentication, role-based access control, remote access, protection of progress photographs and documents, and endpoint security were linked to suitable controls. Medium-level risks related to logging, awareness, segmentation, and data storage were also addressed in a structured manner.

The selected controls directly support the secure implementation of Prismo Constructions. Strong authentication and multi-factor authentication protect user accounts. Role-based access control ensures that CEO, Project Manager, Site Engineer, and Client users only receive appropriate privileges. Secure remote access and encryption protect data when Site Engineers and Clients connect from outside the office. Centralised storage, improved logging, endpoint protection, and basic awareness measures further reduce the likelihood and impact of data leakage, unauthorised access, and operational disruption.

These results provide a solid foundation for the remaining stages of the assessment. Task 6 will translate the selected controls into a concrete To-Be secure network architecture, while Task 7 will present a prioritised implementation plan covering immediate, short-term, and longer-term actions. Together, the ISO 27001 alignment and risk treatment work ensure that security is built into the expanded network and Prismo Constructions platform in a practical and organised way.

6. Secure Network Architecture (To-Be Design)

6.1 Introduction

This section presents the proposed To-Be Secure Network Architecture for Prismo Constructions (PVT) Ltd. The purpose of this design is to translate the requirements, vulnerabilities, and prioritised risks identified in earlier tasks into a practical and secure network environment capable of supporting the Prismo Constructions platform.

The design builds directly on the findings of the previous stages of the assessment. Task 1 established that Prismo Constructions (PVT) Ltd currently operates with a limited IT environment and is expanding into construction management. Task 2 defined the high-level network requirements and logical structure needed to support office users, Site Engineers, and Clients. Task 3 and Task 4 identified significant vulnerabilities and prioritised risks, particularly related to weak authentication, insufficient access control, insecure remote access, unprotected project data and photographs, and limited endpoint security. Task 5 then aligned these risks with ISO/IEC 27001 principles and recommended a set of practical security controls.

The objective of the To-Be architecture is to create a secure, segmented, and scalable network design that addresses these risks while remaining realistic for a small organization. The architecture aims to protect the confidentiality, integrity, and availability of Prismo Constructions and its associated data, support controlled access from multiple locations, and provide a foundation for future growth.

This section outlines the design objectives and principles, describes the proposed security zones and major components, explains how key security controls are integrated into the architecture, and presents the complete To-Be network diagram. It also shows how the selected controls map to the Critical and High risks identified earlier, ensuring that the design is both risk-driven and aligned with the operational needs of Prismo Constructions (PVT) Ltd.

6.2 Design Objectives and Security Goals

The To-Be Secure Network Architecture is designed to provide a practical and effective security foundation for the operation of Prismo Constructions at Prismo Constructions (PVT) Ltd. The main security goals of the architecture are to protect the confidentiality of project and client information, maintain the integrity of progress records and documents, and ensure reliable availability of the system for office staff, Site Engineers, and Clients. The design also aims to enforce least-privilege access, support secure remote connectivity, and create clear trust boundaries between different user groups and system components.

These goals are directly aligned with the risks and business requirements identified in earlier tasks. Critical and High risks related to weak authentication, insufficient role-based access control, insecure remote access, unprotected progress photographs and documents, and limited endpoint protection are addressed through the inclusion of strong authentication, network segmentation, controlled remote access pathways, encryption, and endpoint safeguards. At the same time, the architecture supports the business need for a centralized project management platform that can be accessed from the office, construction sites, and client locations without relying on informal tools such as email and WhatsApp.

The design is shaped by several important constraints. Prismo Constructions (PVT) Ltd is a relatively small organization with limited budget and technical capacity. It does not currently operate a mature enterprise network or a dedicated internal security team. Therefore, the architecture prioritises essential and realistic controls rather than complex or resource-intensive solutions. The design focuses on measures that can be implemented and maintained with moderate cost and effort, while still providing meaningful protection for

the Prismo Constructions environment and supporting the organization's expansion into construction management.

6.3 Design Principles Applied

The To-Be Secure Network Architecture is guided by a set of established design principles that ensure the solution is both secure and practical for Prismo Constructions (PVT) Ltd.

Defense in Depth

Multiple layers of protection are applied so that the failure of a single control does not immediately expose critical systems. Authentication, network segmentation, firewall filtering, endpoint protection, and encryption work together to reduce overall risk. This layered approach is particularly important for an organization that is introducing remote access and external client connectivity for the first time.

Least Privilege

Users are granted only the access required for their role. The CEO, Project Manager, Site Engineer, and Client each receive different levels of permission within Prismo Constructions. This principle limits the potential damage that could result from compromised accounts or accidental misuse and supports clear separation of duties.

Network Segmentation / Zoning

The architecture separates the environment into logical zones, including an Office User Zone, Server / Application Zone, Remote Access Zone, and External Client Access path. By creating defined trust boundaries, the design reduces the likelihood that a compromise in one area will spread freely across the entire network.

Secure Remote Access

Because Site Engineers and Clients must connect from outside the office, remote access is treated as a core design requirement. Encrypted connections and controlled entry points are used to ensure that external users can reach Prismo Constructions without directly exposing the internal application and database environment.

Security by Design

Security controls are built into the architecture from the outset rather than added as an afterthought. The placement of Prismo Constructions, the definition of zones, and the selection of access methods are all driven by the risks identified earlier. This supports a proactive approach that is consistent with the organization's digital transformation goals.

Practicality and Scalability

The design remains realistic for a small organization with limited budget and technical resources. It prioritises essential controls that can be implemented and maintained effectively, while still allowing room for future expansion as the number of users, projects, or sites increases. This balance ensures that the architecture is usable in the near term and adaptable over time.

Together, these principles provide a clear and coherent foundation for the To-Be network design, ensuring that security improvements are meaningful, risk-driven, and suitable for the operational context of Prismo Constructions.

6.4 Proposed To-Be Secure Network Architecture Overview

The proposed To-Be Secure Network Architecture provides a structured and controlled environment to support the secure operation of Prismo Constructions at Prismo Constructions (PVT) Ltd. The design moves the organisation away from its current basic and largely unstructured IT setup toward a segmented architecture that clearly separates internal users, core systems, remote field access, and external client access.

At a high level, the architecture is organised into distinct security zones with defined trust boundaries. The **Office User Zone** supports internal staff such as the CEO, Project Managers, and administrative personnel who access the system from the company premises. The **Server / Application Zone** hosts the Prismo Constructions application and its database and is treated as the most critical and highly protected area of the network. The **Remote Access Zone** enables Site Engineers working at construction sites to connect securely for progress logging, photo uploads, and task updates. An **External / Client Access Path** allows project owners to view progress information and respond to approval requests over the internet with limited privileges. A firewall sits at the main trust boundary between external or remote traffic and the protected application environment.

Prismo Constructions is positioned at the center of this architecture within the Server / Application Zone. All user groups reach the platform through controlled pathways rather than through direct and unrestricted exposure to the internet. Office users connect through the internal network, Site Engineers connect through secured remote access channels, and Clients use a restricted external web access path. This placement ensures that the application and its sensitive data remain behind defined security controls while still supporting the multi-location access requirements of the business.

By establishing clear zones and trust boundaries, the architecture improves visibility and control over how different users interact with the system. It also provides a practical foundation for applying the authentication, access control, encryption, logging, and endpoint protection measures identified in the earlier risk treatment work.

6.5 Detailed Network Zones and Components

The To-Be architecture is divided into clearly defined zones. Each zone has a specific purpose, trust level, and set of controls. This section describes the zones and the major components that support them.

6.5.1 Office User Zone

The Office User Zone represents the internal working environment of Prismo Constructions. It includes the laptops and desktops used by the CEO, Project Managers, and Administrative Officer.

Characteristics:

- Users operate within a relatively trusted internal network.
- Devices connect through the office LAN and then to the Prismo Constructions application.
- Access is controlled by user authentication and role-based permissions.
- This zone is used for project creation, task assignment, monitoring, document management, and overall coordination.

Security focus:

Strong authentication, endpoint protection, and restricted ability to reach the Server / Application Zone only through approved paths.

6.5.2 Server / Application Zone

This is the most critical zone in the architecture. It hosts the core systems of Prismo Constructions.

Main components:

- **Application Server** – Runs the Prismo Constructions web application (React frontend + Spring Boot backend).
- **Database Server** – Stores project data, milestones, tasks, progress logs, user accounts, approval records, and metadata for photos and documents.
- **File Storage** – Securely stores progress photographs and project documents.

Characteristics:

- Highest trust and protection requirements.
- Direct public exposure of the database is not allowed.
- Access is permitted only through controlled interfaces (normally via the application layer and the firewall).
- This zone is the primary target for confidentiality, integrity, and availability protection.

6.5.3 Remote Access Zone

The Remote Access Zone supports Site Engineers who work at construction sites and need to use Prismo Constructions outside the office.

Characteristics:

- Users connect over the public internet from laptops or mobile devices.
- Access is provided through encrypted channels (HTTPS and/or lightweight VPN).
- Site Engineers can submit daily progress logs, upload photographs, update task status, and report issues.
- Their privileges are limited to the projects and tasks assigned to them.

Security focus:

Strong authentication, encrypted communication, session control, and prevention of direct unrestricted access to the Server / Application Zone.

6.5.4 External / Client Access Path

This path allows Clients (project owners) to access Prismo Constructions securely from their own locations.

Characteristics:

- Clients connect over the internet using a web browser.

- They can view project progress, milestones, photographs, and shared documents.
- They can respond to approval or feedback requests.
- Access is strictly limited (read-focused with approval capabilities only).
- Clients cannot access internal office systems or other clients' data.

Security focus:

Encrypted web access, strong authentication, least-privilege permissions, and clear separation from internal network resources.

6.5.5 Management / Security Zone

Although optional for a small organisation, a lightweight Management / Security Zone is recommended.

Purpose:

- Hosts administrative functions such as system monitoring, log collection, backup management, and security configuration.
- Provides a controlled environment for IT support activities.

Typical components:

- Centralised logging / basic monitoring
- Backup management tools
- Administrative access points for system maintenance

This zone helps separate day-to-day user traffic from privileged administrative activities and improves overall control and visibility.

Table 6.5.5.1: Major Components Summary

Component	Role in the Architecture	Security Importance
Firewall	Controls traffic between zones and filters external connections	High – main trust boundary
Application Server	Hosts Prismo Constructions application logic	High – core business system
Database Server	Stores all critical project and user data	Critical – highest value asset
File Storage	Stores progress photos and documents	High – sensitive content
Endpoint Devices	Laptops/mobiles used by staff and Site Engineers	High – common attack entry point
Remote Access Solution	Enables secure connectivity for Site Engineers and Clients	High – expands the attack surface if weak

Logging / Monitoring	Records system and security events	Medium–High – supports detection and accountability
-----------------------------	------------------------------------	---

These zones and components together create a practical, segmented, and risk-driven architecture that protects Prismo Constructions while remaining suitable for the size and resources of Prismo Constructions (PVT) Ltd.

6.6 Security Controls Integrated into the Architecture

The To-Be Secure Network Architecture incorporates a practical set of security controls that directly address the Critical and High risks identified earlier. These controls are embedded into the design rather than treated as optional additions.

Authentication and Access Control

All users must authenticate before accessing Prismo Constructions. Strong password requirements are enforced, and multi-factor authentication (MFA) is recommended, especially for remote users (Site Engineers and Clients). Role-Based Access Control (RBAC) ensures that each user only receives the privileges appropriate to their role (CEO, Project Manager, Site Engineer, or Client). This directly mitigates risks related to weak authentication, shared passwords, and excessive privileges.

Firewall and Perimeter Protection

A firewall forms the primary perimeter control. It filters traffic between the Internet, the Remote Access Zone, the External Client path, and the Server / Application Zone. Only required services (mainly HTTPS) are permitted, reducing the attack surface and limiting unauthorised connection attempts.

Secure Remote Access (VPN / HTTPS)

Site Engineers and Clients connect to Prismo Constructions over encrypted channels. HTTPS is mandatory for all web access. Where broader internal access is required for Site Engineers, a lightweight VPN or equivalent secure remote access solution is used. This prevents the interception of data in transit and avoids direct exposure of internal systems.

Network Segmentation

Logical separation between the Office User Zone, Server / Application Zone, Remote Access Zone, and External Client path creates clear trust boundaries. This limits lateral movement if one zone is compromised and supports the principle of least privilege at the network level.

Endpoint Protection

Laptops and mobile devices used by staff and Site Engineers are protected with up-to-date antivirus/anti-malware software, strong device authentication, and basic security configuration. This reduces the risk of malware infection and the impact of lost or stolen devices.

Encryption (in Transit and at Rest)

All communication with Prismo Constructions is encrypted using HTTPS/TLS. Sensitive data stored in the database and file storage (including progress photographs and documents) should be protected with encryption at rest where feasible. This safeguards confidentiality if data is intercepted or storage media is compromised.

Logging and Monitoring

System and security logs are collected from applications, authentication services, and key infrastructure components. Basic monitoring enables detection of unusual login attempts, access violations, or system errors. This improves accountability and supports incident investigation.

Backup and Recovery

Regular backups of the Prismo Constructions database and critical files are performed and stored securely. This ensures that project data, progress records, and documents can be restored in the event of system failure, ransomware, or accidental deletion, supporting availability and business continuity.

Other Relevant Controls

Additional supporting measures include secure configuration of the application and database, restriction of administrative privileges, timely software updates and patching, and basic security awareness for staff. Together, these controls create a layered defense that is realistic for a small organisation while significantly improving the security posture of the Prismo Constructions environment.

6.7 Mapping of Controls to Identified Risks

The To-Be architecture incorporates specific security controls that directly address the Critical and High risks identified in Task 4. The following table shows the mapping between these risks and the corresponding architectural controls.

Table 6.7.1: Mapping of Architectural Controls to Critical and High Risks

Risk ID	Risk Description	Risk Level	Architectural Controls Applied	How the Control Reduces the Risk
R01	Weak authentication / Absence of MFA	Critical	Strong password policy + Multi-Factor Authentication + Centralised login	Prevents easy account compromise even if passwords are stolen
R02	Insufficient role-based access control	Critical	Role-Based Access Control (RBAC) + Least Privilege	Ensures users can only access data and functions relevant to their role
R03	Insecure handling of progress photos and documents	Critical	Centralised secure file storage + Access-controlled document sharing	Removes reliance on email/WhatsApp and restricts who can view files
R04	Weak remote access controls	Critical	Encrypted HTTPS access + Controlled Remote Access Zone + Session controls	Protects Site Engineer connections and prevents direct exposure of internal systems
R05	Limited firewall protection / Insecure internet exposure	High	Firewall as primary perimeter control + Restricted external ports	Filters unwanted traffic and limits the external attack surface

R06	Lost or stolen devices / Limited endpoint protection	High	Endpoint protection + Device authentication + Data minimisation	Reduces impact if a laptop or mobile device is lost or compromised
R07	Heavy reliance on email and WhatsApp	High	Mandatory use of Prismo Constructions for project communication and approvals	Moves sensitive information into a controlled system with audit trails
R08	Lack of encryption for sensitive data	High	HTTPS/TLS for data in transit + Encryption at rest where feasible	Protects project data, photos, and credentials from interception or unauthorised access

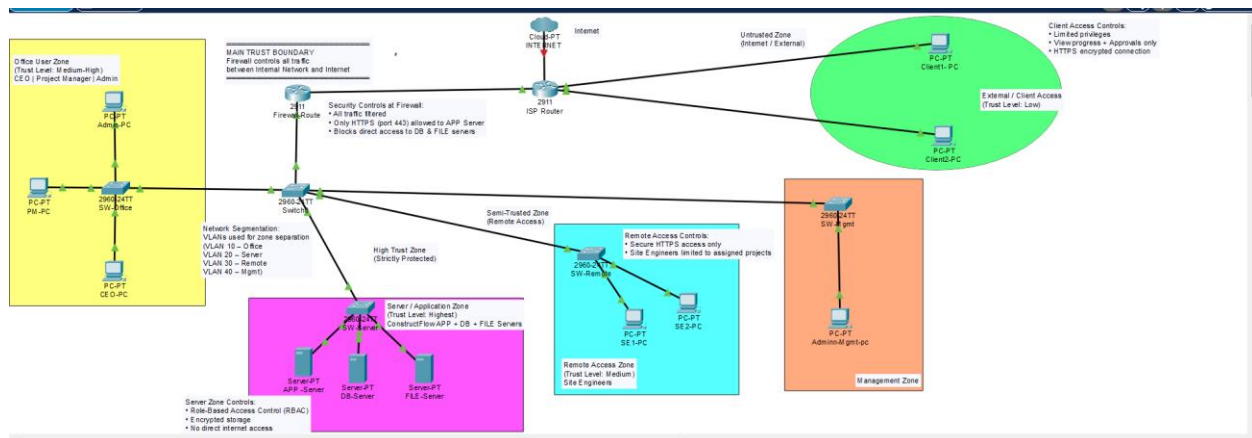
Justification of Key Design Decisions

The architecture prioritises controls that deliver the highest risk reduction for the lowest practical complexity. Strong authentication and RBAC were selected as foundational controls because they address the two most critical access-related risks and protect all other assets. A dedicated Server / Application Zone behind a firewall was introduced to prevent direct internet exposure of Prismo Constructions and its database. Secure remote access and encrypted communications were included because Site Engineers and Clients must connect from outside the office. Centralised storage for photographs and documents was designed to eliminate the current insecure practice of sharing files via WhatsApp and email. Endpoint protection and encryption were added to reduce the impact of device loss and data interception, both of which are realistic risks in a construction environment.

These design decisions ensure that every major control in the To-Be architecture is risk-driven, directly traceable to the earlier assessment, and realistic for a small organisation implementing a new digital platform.

6.8 To-Be Secure Network Diagram

The logical To-Be Secure Network Architecture for Prismo Constructions (PVT) Ltd is shown below. The diagram clearly separates the different security zones, identifies the main trust boundaries, and shows how major controls protect Prismo Constructions.



The diagram presents the complete logical To-Be Secure Network Architecture designed for Prismo Constructions (PVT) Ltd to support the Prismo Constructions platform.

Key Zones shown:

- **Office User Zone** – Contains the CEO, Project Manager, and Administrative Officer using protected office laptops. This is a relatively trusted internal zone.
- **Remote Access Zone** – Supports Site Engineers connecting from construction sites using mobile devices or laptops over encrypted channels (HTTPS or lightweight VPN).
- **External / Client Access Path** – Allows Clients (project owners) to securely view progress and respond to approvals using a web browser over HTTPS only.
- **Server / Application Zone** – The highest-trust zone that hosts the Prismo Constructions Application Server, Database Server, and Secure File Storage for progress photographs and documents. This zone has no direct public exposure.
- **Management / Security Zone** – Handles centralised logging, monitoring, and backup management, separating administrative functions from normal user traffic.

Main Trust Boundary

The firewall acts as the primary trust boundary. All traffic from the Internet, Site Engineers, and Clients must pass through it before reaching the Server / Application Zone. Only necessary encrypted traffic (mainly HTTPS) is permitted.

Security Controls Visible in the Diagram

- Encryption of all external connections (HTTPS)
- Network segmentation between zones
- Role-based user separation
- Endpoint protection on office and field devices
- Centralised logging and backup
- Protection of the database and file storage behind the application layer

This architecture provides clear separation of users and systems, reduces the attack surface, and supports the secure multi-location operation of Prismo Constructions while remaining practical for a small organisation.

6.9 Scalability and Future Considerations

The To-Be Secure Network Architecture has been designed so that it can grow with Prismo Constructions as the organisation expands its construction management activities. The current design focuses on essential controls that are realistic for a small company, while still providing a clear structure that can be extended without requiring a complete redesign.

As the number of projects, Site Engineers, and Clients increases, additional users can be added within the existing zones without changing the overall architecture. New Site Engineers can connect through the same Remote Access Zone, and new Clients can use the same controlled external access path. The Server /

Application Zone can be scaled by increasing the capacity of the application and database servers or by moving to a more robust cloud hosting arrangement if required. Network segmentation already separates different user groups, so growth in one area does not automatically increase risk in another.

Several future enhancements can be introduced as the organisation matures and resources allow. Multi-factor authentication can be extended to all user roles. More advanced monitoring or a lightweight SIEM solution can be added to improve detection of security events. Additional network segmentation, such as separating development and production environments, can be introduced if the system grows further. Endpoint management tools, automated backup verification, and more formal security policies can also be implemented over time. If the company expands to multiple office locations or larger project volumes, the same zone-based design can be replicated or extended with stronger inter-site connectivity.

By establishing clear zones, trust boundaries, and core security controls from the beginning, the architecture provides a practical foundation for the present while remaining flexible enough to support the future growth of Prismo Constructions (PVT) Ltd and the Prismo Constructions platform.

6.10 Summary of Task 6

Task 6 has presented a practical To-Be Secure Network Architecture for Prismo Constructions (PVT) Ltd to support the secure operation of the Prismo Constructions platform. The design is based on the requirements, vulnerabilities, and prioritised risks identified in the earlier stages of the assessment and is aligned with the control recommendations developed under ISO/IEC 27001 guidance.

The key features of the architecture include clear network zoning, a defined primary trust boundary controlled by a firewall, strong authentication and role-based access control, encrypted remote and client access, endpoint protection, centralised secure storage for progress photographs and documents, logging and monitoring, and regular backup and recovery. These elements create a segmented environment that separates Office Users, Site Engineers, Clients, and the core Server / Application Zone hosting Prismo Constructions (PVT) Ltd.

This design supports the secure operation of Prismo Constructions by ensuring that sensitive project data, progress records, and client information are protected according to the principles of confidentiality, integrity, and availability. Site Engineers and Clients can access the system from external locations without directly exposing the application and database. Internal users operate within a controlled environment, and the overall architecture reduces the risks associated with weak authentication, insecure file sharing, limited remote access controls, and inadequate endpoint protection.

The To-Be architecture provides a realistic and risk-driven foundation for implementation. Task 7 will build on this design by defining clear implementation priorities, distinguishing between immediate actions, short-term improvements, and longer-term enhancements. This ensures that the most critical security controls are introduced first and that the organisation can progressively strengthen its security posture in a structured and manageable way.

7. Recommendations and Implementation Priorities

7.1 Introduction

This section presents the prioritised security recommendations and implementation plan for Prismo Constructions (PVT) Ltd. The purpose of these recommendations is to translate the findings of the full assessment into a clear, practical, and realistic set of actions that the organisation can follow to improve its information security posture while implementing the Prismo Constructions platform.

The recommendations are directly based on the work completed in the previous tasks. Task 1 identified the limited current IT environment and the business need for secure digital transformation. Task 2 defined the required network capabilities. Tasks 3 and 4 identified significant vulnerabilities and prioritised the associated risks. Task 5 aligned these risks with ISO/IEC 27001 principles and selected appropriate controls. Task 6 then developed a To-Be Secure Network Architecture that incorporates these controls in a structured and practical design.

The recommendation approach focuses on prioritisation rather than attempting to implement every possible control at once. Recommendations are grouped into Immediate, Short-Term, and Medium-Term priorities based on risk level, business impact, feasibility, and resource requirements. This structured approach ensures that the most critical weaknesses are addressed first.

Prioritisation is especially important for a small organisation such as Prismo Constructions (PVT) Ltd. The company has limited budget, technical capacity, and internal security expertise. A phased and realistic implementation plan allows the organisation to make meaningful security improvements without overloading its resources, while still supporting the secure and successful introduction of Prismo Constructions.

7.2 Recommendation Approach and Prioritization Criteria

The security recommendations for Prismo Constructions (PVT) Ltd were developed through a structured and risk-driven approach. Rather than listing every possible improvement, the recommendations focus on actions that deliver the greatest reduction in risk while remaining practical for a small organization implementing Prismo Constructions.

Recommendations were prioritized using a combination of the following criteria:

- **Risk Level** – Critical and High risks identified in Task 4 were given the highest priority for treatment.
- **Business Impact** – Controls that protect core business activities (project management, site progress tracking, client communication, and document sharing) were prioritised over less essential measures.
- **Feasibility** – Recommendations were assessed for technical practicality within the current skills and infrastructure of the organisation.

- **Cost** – Preference was given to controls that provide strong protection at reasonable cost, avoiding unnecessarily expensive enterprise solutions.
- **Effort and Complexity** – Controls that can be implemented relatively quickly and maintained with limited resources were ranked higher than complex or resource-intensive measures.

This prioritisation process is consistent with the ISO/IEC 27001 risk treatment decisions made in Task 5. The recommended actions primarily follow the “Mitigate” treatment option for Critical and High risks by applying appropriate Annex A controls. Where residual risk remains after treatment, the organisation may choose to formally accept or continue monitoring those risks. The overall approach ensures that security improvements are targeted, justified, and aligned with both the risk assessment results and the operational realities of Prismo Constructions.

7.3 Prioritized Security Recommendations

The following recommendations are organised into three priority levels based on risk severity, business impact, and practical feasibility for Prismo Constructions (PVT) Ltd.

Immediate Priority (0–1 month)

These controls address the most Critical risks and should be implemented as soon as possible, ideally before or during the initial deployment of Prismo Constructions.

Table 7.3.1: Immediate Priority (0–1 month)

No.	Recommendation	Related Risk(s)	Expected Benefit
1	Enforce strong password policy for all user accounts	R01 (Weak authentication)	Reduces risk of easy account compromise
2	Implement Multi-Factor Authentication (MFA), especially for remote users and privileged accounts	R01	Significantly strengthens login security
3	Configure Role-Based Access Control (RBAC) according to defined roles (CEO, PM, Site Engineer, Client)	R02	Enforces least privilege from the start
4	Ensure all access to Prismo Constructions uses HTTPS only	R04, R08	Protects data in transit
5	Move project documents and progress photos into Prismo Constructions secure storage (stop using WhatsApp/email for sensitive files)	R03, R07	Eliminates major data leakage channel

Short-Term Priority (1–3 months)

These improvements strengthen the overall architecture and address remaining High risks after the immediate controls are in place.

Table 7.3.2: Short-Term Priority (1–3 months)

No.	Recommendation	Related Risk(s)	Expected Benefit
6	Deploy a properly configured firewall as the main perimeter control	R05	Limits external attack surface and enforces zone separation
7	Implement basic endpoint protection (antivirus + device security settings) on all office and field devices	R06	Reduces impact of malware and lost/stolen devices
8	Enable encryption at rest for the database and file storage where feasible	R08	Protects sensitive data if storage is compromised
9	Establish basic centralised logging of authentication and key system events	Supporting control	Improves visibility and supports incident investigation
10	Conduct basic security awareness briefing for all staff (especially Site Engineers)	Human-related risks	Reduces risky behaviour and improves compliance

Medium-Term Priority (3–6 months)

These controls build security maturity and support long-term sustainability of the Prismo Constructions environment.

Table 7.3.0.3: Medium-Term Priority (3–6 months)

No.	Recommendation	Related Risk(s)	Expected Benefit
11	Formalize a simple backup and recovery procedure with regular testing	Availability risks	Ensures business continuity if data is lost
12	Introduce a lightweight VPN or equivalent secure remote access solution for Site Engineers (if broader access is required)	R04	Provides stronger control over remote connections
13	Develop and document basic information security policies (acceptable use, access control, incident reporting)	Supporting control	Creates clear expectations and accountability
14	Schedule periodic review of user access rights and system configurations	R02 and ongoing risks	Maintains least privilege over time
15	Plan for future monitoring improvements (e.g., basic alerting or lightweight SIEM) as the organisation grows	Future risk management	Builds detection capability gradually

This prioritised structure ensures that Prismo Constructions (PVT) Ltd addresses the highest risks first while progressively strengthening the security of Prismo Constructions in a realistic and manageable way.

7.4 Detailed Recommendation Table

The following table consolidates the prioritised security recommendations for Prismo Constructions (PVT) Ltd. It shows each recommendation, the related risks, priority level, expected benefit, and the anticipated residual risk after implementation.

Table 7.4.1: Detailed Security Recommendations

Rec ID	Description	Related Risk(s)	Priority	Expected Benefit	Residual Risk after Implementation
REC-01	Enforce strong password policy for all Prismo Constructions user accounts	R01	Immediate (0–1 m)	Reduces likelihood of weak or easily guessed passwords	Low
REC-02	Implement Multi-Factor Authentication (MFA) for all users, especially remote and privileged accounts	R01	Immediate (0–1 m)	Significantly reduces risk of account compromise	Low
REC-03	Configure and enforce Role-Based Access Control (RBAC) according to defined roles (CEO, Project Manager, Site Engineer, Client)	R02	Immediate (0–1 m)	Ensures users only have access required for their role	Low
REC-04	Mandate HTTPS-only access to Prismo Constructions for all users	R04, R08	Immediate (0–1 m)	Protects data in transit from interception	Low
REC-05	Migrate all project documents and progress photographs into Prismo Constructions secure storage; discontinue use of WhatsApp and email for sensitive files	R03, R07	Immediate (0–1 m)	Eliminates major uncontrolled data leakage channels	Low–Medium
REC-06	Deploy and properly configure a firewall as the primary perimeter control	R05	Short-Term (1–3 m)	Limits external attack surface and enforces zone separation	Low

REC-07	Install and maintain endpoint protection (antivirus + basic device security settings) on all office and field devices	R06	Short-Term (1–3 m)	Reduces impact of malware and lost/stolen devices	Low–Medium
REC-08	Enable encryption at rest for the database and file storage where feasible	R08	Short-Term (1–3 m)	Protects sensitive data if storage media is compromised	Low
REC-09	Enable basic centralised logging of authentication events and key system activities	Supporting	Short-Term (1–3 m)	Improves visibility and supports incident investigation	Medium
REC-10	Conduct basic security awareness briefing for all staff, with emphasis on Site Engineers	Human-related risks	Short-Term (1–3 m)	Reduces risky behaviour and improves compliance	Medium
REC-11	Formalise a simple backup and recovery procedure and perform regular restore tests	Availability risks	Medium-Term (3–6 m)	Ensures recovery of critical project data	Low
REC-12	Introduce a lightweight VPN or equivalent secure remote access solution for Site Engineers (if broader access is required)	R04	Medium-Term (3–6 m)	Provides stronger control over remote connections	Low
REC-13	Develop and document basic information security policies (acceptable use, access control, incident reporting)	Supporting	Medium-Term (3–6 m)	Creates clear expectations and accountability	Medium
REC-14	Schedule periodic review of user access rights and system configurations	R02 + ongoing	Medium-Term (3–6 m)	Maintains least privilege over time	Low
REC-15	Plan for future monitoring improvements (basic alerting or lightweight SIEM) as the organisation grows	Future risk management	Medium-Term (3–6 m)	Builds progressive detection capability	Medium

7.5 Implementation Considerations

Successful implementation of the recommended security controls requires careful attention to the practical realities of Prismo Constructions (PVT) Ltd. As a small organisation expanding into construction management, the company faces several constraints that influence how and when the recommendations can be applied.

Practical Constraints

Budget is limited, so expensive enterprise security solutions are not realistic in the short term. Technical skills within the organisation are also limited; there is currently no dedicated internal IT security team. Time is another constraint, as staff are focused on project delivery and the rollout of Prismo Constructions. Therefore, recommendations have been selected and prioritised to deliver meaningful risk reduction with moderate cost, manageable complexity, and realistic effort.

Change Management and User Awareness

Moving from informal tools such as email and WhatsApp to a controlled platform will require behavioural change. Site Engineers and other staff must be supported through clear communication and basic security awareness. A short awareness briefing is recommended so that users understand why new controls (such as MFA, restricted file sharing, and role-based access) are being introduced and how to use them correctly. Without user cooperation, even well-designed technical controls may be bypassed or poorly applied.

Dependency between Recommendations

Some recommendations depend on others. Strong authentication and Role-Based Access Control should be established before expanding remote access. Secure storage of documents and photographs should be available before staff are required to stop using WhatsApp and email for sensitive files. The firewall and network zoning should be in place before broader external connectivity is enabled. Implementing controls in the recommended priority order helps avoid gaps and reduces the chance of introducing new risks during the transition.

Responsibility for Implementation

Given the size of the organisation, clear ownership is essential:

- **CEO** – Provides overall authority, approves priority actions, and ensures resources are allocated.
- **Project Manager** – Supports day-to-day coordination of Prismo Constructions usage and reinforces correct security practices within project teams.
- **Administrative / System Support role** – Handles practical configuration tasks (user accounts, basic system settings, backup checks) with external technical support if required.
- **All users (including Site Engineers and Clients)** – Are responsible for following the defined access rules and secure working practices.

Where specialised technical skills are needed (for example, firewall configuration or encryption setup), Prismo Constructions may need to engage external support on a limited basis. This combination of internal ownership and selective external assistance offers a practical way to implement the recommendations without overloading the organisation.

7.6 Residual Risk Overview

After the recommended security controls are implemented according to the prioritised plan, the overall risk exposure of Prismo Constructions is expected to reduce significantly. Most Critical and High risks identified in Task 4 will move to Low or Low–Medium residual risk levels, provided the controls are applied correctly and maintained.

Table 7.6.1: Expected Residual Risk Levels

Risk ID	Original Risk Description	Original Level	Expected Residual Risk	Comments
R01	Weak authentication / Absence of MFA	Critical	Low	Strong passwords + MFA substantially reduce this risk
R02	Insufficient role-based access control	Critical	Low	Proper RBAC and periodic access reviews keep residual risk low
R03	Insecure handling of progress photos and documents	Critical	Low–Medium	Centralised secure storage removes the main exposure; residual risk remains from user behaviour
R04	Weak remote access controls	Critical	Low	HTTPS + controlled remote access significantly reduces exposure
R05	Limited firewall protection / Insecure internet exposure	High	Low	Properly configured firewall addresses the primary weakness
R06	Lost or stolen devices / Limited endpoint protection	High	Low–Medium	Endpoint protection helps, but physical loss of devices remains a residual concern
R07	Heavy reliance on email and WhatsApp	High	Low–Medium	Migration to Prismo Constructions reduces this risk, but occasional informal use may continue
R08	Lack of encryption for sensitive data	High	Low	Encryption in transit and at rest (where implemented) provides strong protection

Risks that May Need to be Accepted or Monitored

Even after successful implementation, some residual risks will remain and should be formally acknowledged:

- **Human and behavioural risks** – Users may still attempt to share files informally or reuse weak practices under time pressure. These risks should be monitored through awareness reinforcement and periodic checks.
- **Endpoint and physical risks** – Loss or theft of Site Engineer devices cannot be completely eliminated. Residual risk should be accepted at a Low–Medium level and managed through device protection and rapid access revocation.
- **Emerging threats** – New vulnerabilities or attack methods may appear over time. These should be monitored through regular review of system updates, access logs, and security practices.
- **Resource limitations** – As a small organisation, Prismo Constructions may not be able to implement advanced detection capabilities immediately. Related residual risks should be accepted in the short term and revisited as the organisation grows.

Overall, the residual risk profile after implementing the recommended controls is considered acceptable for a small organisation operating the Prismo Constructions platform, provided that the controls are maintained and periodically reviewed.

7.8 Summary of Task 7

Task 7 has presented a prioritised and practical set of security recommendations to guide Prismo Constructions (PVT) Ltd in strengthening its information security posture while implementing the Prismo Constructions platform.

The key recommendations focus first on the most critical weaknesses: enforcing strong authentication and Multi-Factor Authentication, implementing Role-Based Access Control, ensuring HTTPS-only access, and moving sensitive project documents and progress photographs into controlled storage within Prismo Constructions. These immediate actions are followed by short-term improvements such as firewall deployment, endpoint protection, encryption, basic logging, and staff awareness. Medium-term actions then build maturity through formal backup procedures, improved remote access controls, basic security policies, and periodic access reviews.

Overall, successful implementation of these recommendations is expected to reduce the majority of Critical and High risks to Low or Low–Medium residual levels. This will significantly improve the confidentiality, integrity, and availability of Prismo Constructions and its associated data, while remaining realistic for a small organisation with limited resources.

This final set of recommendations completes the full assessment process. Tasks 1 to 6 established the business context, network requirements, vulnerabilities, risks, ISO/IEC 27001 alignment, and the To-Be secure architecture. Task 7 translates those findings into clear, prioritised actions. Together, the seven tasks provide Prismo Constructions (PVT) Ltd with a coherent, risk-driven, and practical roadmap for securing its expanded network and digital project management platform.

8. Conclusion

This report has presented a complete information security assessment for Prismo Constructions (PVT) Ltd as the organisation expands from construction consultancy into construction management and introduces the Prismo Constructions digital platform. The assessment covered the current business and network environment, identification of vulnerabilities, formal risk assessment, alignment with ISO/IEC 27001 principles, design of a practical To-Be secure network architecture, and a prioritised set of implementation recommendations.

The analysis showed that the existing IT environment is limited and heavily dependent on informal tools such as email and WhatsApp. This creates significant security weaknesses, particularly in authentication, access control, remote connectivity, protection of progress photographs and documents, and endpoint security. Several Critical and High risks were identified that would expose project data, client information, and system availability if left unaddressed.

Through the application of ISO/IEC 27001-aligned controls and the design of a segmented To-Be network architecture, these risks can be substantially reduced. The proposed architecture establishes clear security zones, a strong perimeter firewall, encrypted remote and client access, role-based access control, and protected storage for sensitive files. When the prioritised recommendations are implemented starting with strong authentication, multi-factor authentication, role-based access, HTTPS enforcement, and secure document handling the majority of Critical and High risks are expected to fall to Low or Low–Medium residual levels.

The assessment provides Prismo Constructions (PVT) Ltd with a realistic and risk-driven roadmap that supports the secure introduction of Prismo Constructions while remaining suitable for a small organisation with limited resources. Although the study was constrained by time, available technical detail, and the absence of full penetration testing, the findings and recommendations remain valid and actionable.

The highest priority actions are the immediate implementation of strong authentication and multi-factor authentication, proper role-based access control, mandatory HTTPS access, migration of sensitive files into Prismo Constructions, and deployment of basic perimeter and endpoint protections. These should be followed by the short-term and medium-term improvements outlined in the recommendations.

By adopting a phased and practical approach to security, Prismo Constructions (PVT) Ltd can protect its project data, enable safe collaboration with Site Engineers and Clients, and build a more resilient digital foundation. This will support both the successful operation of Prismo Constructions and the organisation's longer-term growth in the construction management sector.

9. References

- [1] International Organization for Standardization, *ISO/IEC 27001:2022 – Information security, cybersecurity and privacy protection — Information security management systems — Requirements*, Geneva, Switzerland: ISO, 2022.
- [2] International Organization for Standardization, *ISO/IEC 27002:2022 – Information security, cybersecurity and privacy protection — Information security controls*, Geneva, Switzerland: ISO, 2022.
- [3] National Institute of Standards and Technology, *Guide for Conducting Risk Assessments*, NIST Special Publication 800-30 Revision 1, Gaithersburg, MD, USA: NIST, 2012.
- [4] National Institute of Standards and Technology, *Security and Privacy Controls for Information Systems and Organizations*, NIST Special Publication 800-53 Revision 5, Gaithersburg, MD, USA: NIST, 2020.
- [5] Open Web Application Security Project (OWASP), “OWASP Top 10 – 2021: The Ten Most Critical Web Application Security Risks,” 2021. [Online]. Available: <https://owasp.org/Top10/>. [Accessed: 28-Sep-2026].
- [6] Prismo Constructions (PVT) Ltd., “Prismo Constructions – Construction Consultancy Sri Lanka,” 2026. [Online]. Available: <https://prismoconstructions.com/>. [Accessed: 15-Sep-2026].
- [7] SANS Institute, “Network Security Architecture and Design Principles,” 2023. [Online]. Available: <https://www.sans.org/>. [Accessed: 20-Sep-2026].
- [8] W. Stallings and L. Brown, *Computer Security: Principles and Practice*, 4th ed. Harlow, UK: Pearson Education, 2018.
- [9] M. E. Whitman and H. J. Mattord, *Principles of Information Security*, 7th ed. Boston, MA, USA: Cengage Learning, 2021.
- [10] Sri Lanka Institute of Information Technology, “IE3101 – Enterprise Network and Information Systems Security Assignment Guideline,” 2026.
- [11] “ISO 27001 Toolkit Materials, Network Diagrams, Cisco Packet Tracer Files and Assessment Evidence for Prismo Constructions – ConstructFlow,” Google Drive, 2026. [Online]. Available: https://drive.google.com/drive/folders/1aClmEG_ipNHRL0QrT_kPWl35ngVDA4o9?usp=drive_link. [Accessed: 02-Oct-2026].

Appendices

The following appendices contain the detailed supporting documents and artefacts produced during the assessment of Prismo Constructions.

Appendix A – Information Asset Register

Complete Information Asset Register developed in accordance with the ISO/IEC 27001 Toolkit. Includes asset identification, classification (Confidentiality, Integrity, Availability), ownership, and valuation for critical information assets related to Prismo Constructions and the expanded network environment.

List of Digital assets and Valuation of Digital Assets					List of People assets and Valuation of People Assets													
Prismo Constructions					Prismo Constructions													
Version Number 1.0					Version Number 1.0													
Dt. 15.09.2026					Dt. 16.08.2026													
#	Asset Title	Asset Details			Value	#	Role	Role Details			Value							
1	Project Master Data	Asset ID	Project Manager	High	H	1	CEO	Department	Top Management	High	H							
		Custodian	Admin Officer															
		Users	CEO, PM, Site Engineers															
		Location	ConstructFlow DB															
		Storage Details	Project details, milestones, status, portfolio overview															
		Classification	Confidential															
		Life Cycle																
		Disposal Method																
		Backup Schedule																
		Backup Location																
		Confidentiality Requirements																
		Integrity Requirements																
		Availability Requirements																
		Daily Progress Logs	Asset ID					Site Engineer					2	Project Manager	Department	Project Management		
			Owner					Project Manager							Reporting to	AI project data, approvals, tasks		
	Custodian	PM, CEO, Client			Access to High Value Info. Assets													
	Users	ConstructFlow DB			Alternate Role													
	Location				NDA Requirements	Yes												
Index Digital Asset Business Databases Source Code Software Non Digital Assets					Index Digital Asset Business Databases Source Code Software Non Digital Assets													

Google Drive - https://docs.google.com/spreadsheets/d/1GDjcAZtcR5pPs-oUEwhXlbFiw1YxjCdS/edit?usp=drive_link&ouid=105300668872313040311&rtpof=true&sd=true

Appendix B – Information Classification Matrix

ISO 27001 security INFORMATION CLASSIFICATION MATRIX AND HANDLING GUIDE Prismo Constructions							
CATEGORY	DESCRIPTION	Sample Documents/Records	MARKING	PHYS & ADMIN CONTROLS	REPRODUCTION	DISTRIBUTION	DESTRUCTION/ DISPOSAL
PUBLIC	Information that can be freely shared without causing any damage to the company or its clients.	- Company website content - Marketing brochures - Public project photos (with client permission) - General contact information	None	None	Unlimited	No restrictions	Normal recycling / trash
INTERNAL	Information for internal use only. Disclosure outside the company would be inappropriate or inconvenient.	- Internal project status summaries - Task lists (non-sensitive) - Staff contact lists - Training materials - Internal meeting notes - Non-sensitive progress reports	"INTERNAL USE ONLY" (bottom of page)	Author must mark correctly. Users must store properly.	Limited copies by authorized staff only	Internal email or ConstructFlow only. External sharing needs PM approval	Paper: Shred Electronic: Secure delete
CONFIDENTIAL	Highly sensitive information. Unauthorized disclosure can cause significant damage to the company, clients, or projects.	- Full project details & milestones - Daily progress logs - Site progress photographs - Client contracts, drawings & BOQ - Approval requests & decisions - User credentials & access logs - Issue/defect reports with photos - Cost & budget information	"CONFIDENTIAL" (bottom of page)	Strict need-to-know basis. Must be encrypted. Access only through ConstructFlow RBAC + MFA	Only with permission of Project Manager or CEO	Only through ConstructFlow. Never via WhatsApp, personal email, or unencrypted channels	Paper: Cross-cut shredder Electronic: Secure wipe Devices returned to Admin for disposal

+

≡

Classification matrix ▾

Copyright ▾

Sheet3 ▾

Google Dive -

https://docs.google.com/spreadsheets/d/1fir0bh_S71iRiS0QvPx4Ib_HEGnZ3U8D/edit?usp=drive_link&ouid=105300668872313040311&rtpof=true&sd=true

Appendix C – Risk Register

Full ISO/IEC 27001-aligned Risk Register containing all prioritised risks identified in Task 4. Includes Risk ID, Asset, Vulnerability, Threat, Likelihood, Impact, Risk Level, existing controls, and recommended treatment actions.

Risk ID		Asset owner	Impact	Raw probability	Raw impact	Raw risk rating	Treatment	Treatment cost	Treatment status	Treated probability	Treated impact	Target risk rating	Current risk rating	Notes				
Risk																		
R01	Weak authentication and absence of Multi-Factor Authentication (MFA)	Admin Officer	Unauthorized access to ConstructFlow, theft or modification of project data and client information	85%	80%	43%	Enforce strong password policy + implement MFA for all users (especially remote and privileged accounts)	80,000 LKR	10%	20%	50%	10%	42%	Critical risk. Highest priority for immediate treatment.				
R02	Insufficient Role-Based Access Control (RBAC)	Project Manager	Users accessing data beyond their role (e.g. Site Engineer seeing all projects, Client seeing other clients' data)	80%	75%	40%	Configure and enforce proper RBAC according to roles (CEO, PM, Site Engineer, Client) + periodic access reviews	40,000 LKR	10%	15%	40%	6%	55%	Critical. Must be implemented before system goes live.				
R03	Insecure handling and storage of progress photos and project documents (WhatsApp, email, personal devices)	Project Manager	Data leakage, loss of confidentiality, unauthorized sharing of sensitive construction data	90%	70%	63%	Migrate all progress photos and documents into ConstructFlow secure storage. Prohibit use of WhatsApp/email for sensitive files.	60,000 LKR	5%	20%	40%	8%	60%	Critical. Major current operational risk.				
R04	Weak remote access controls for Site Engineers and Clients	Project Manager	Unauthorized remote access, man-in-the-middle attacks, data interception	75%	70%	53%	Enforce HTTPS only + controlled remote access (VPN or secure web access) + MFA	100,000 LKR	10%	20%	40%	8%	48%	High/Critical. Essential for field and client access.				
R05	Limited or missing firewall and network segmentation	Admin Officer	External attackers reaching internal servers and application	70%	75%	53%	Deploy and properly configure firewall as main perimeter control + implement network zones (Office, Server, Remote)	150,000 LKR	5%	15%	40%	6%	50%	High. Required for To-Be architecture.				
R06	Lost or stolen Site Engineer devices with limited endpoint protection	Site Engineer	Loss of sensitive progress data and possible unauthorized access	65%	65%	42%	Install endpoint protection (antivirus + basic device security) on all office and field devices + rapid account disable process	70,000 LKR	10%	25%	40%	10%	39%	High. Physical risk remains partially residual.				

<

>

Introduction

Risk register

Worked example

Guidance on usage

Guidance on scoring

+

⋮

Google Dive -

https://drive.google.com/file/d/1HZY1EDsf1wh7CQSz7CQbVRUrt5DjhQOp/view?usp=drive_link

Appendix D – Statement of Applicability (SoA)

High-level Statement of Applicability showing the ISO/IEC 27001 Annex A controls selected for Prismo Constructions (PVT) Ltd. Indicates which controls are applicable, the justification for inclusion, and any controls considered not applicable.

B

C

D

E

F

G

H

I

J

K

L

2

3

4

5

6

7

8

9

10

11

12

13

14

15

Statement of Applicability

Current as of: 02/10/2026

Legend (for Selected Controls and Reasons for controls selection)

LR: legal requirements, CO: contractual obligations, BR/BP: business requirements/adopted best practices, RRA: results of risk assessment, TSE: to some extent

ISO/IEC 27001:2013 Annex A controls			Current controls	Remarks (with justification for exclusions)	Selected controls and reasons for selection				Remarks (overview of implementation)	
Clause	Sec	Control Objective/Control			LR	CO	BR/BP	RRA		
5	Security Policies	5.1	Management direction for information security							
		5.1.1	Policies for information		Basic information security policy is required to set direction for ConstructFlow			X	X	Planned – simple policy to be written
		5.1.2	Review of the policies for information security		Annual review is practical for small organization			X		Planned
		6.1	Internal organisation							
		6.1.1	Information security roles and responsibilities		Roles defined (CEO, PM, Admin Officer, Site Engineer)			X	X	Partially Implemented
		6.1.2	Segregation of duties		Important to separate project creation, approval and field data entry				X	Planned via RBAC

< >

Intro & copyright

SoA English

SoA Spanish

+

<

Google Drive- https://docs.google.com/spreadsheets/d/1eA4NR-Z3SzxANtckCUyhD3U__5j7y-Z/edit?usp=sharing&ouid=105300668872313040311&rtpof=true&sd=true

Status of ISO/IEC 27001 implementation			
Section	ISO/IEC 27001 requirement	Status	Notes
4	Context of the organisation		
4.1	Organisational context		
4.1	Determine the organization's ISMS objectives and any issues that might affect its effectiveness	Defined	Context of Prismo Constructions and ConstructFlow has been clearly documented in the report
4.2	Interested parties		
4.2 (a)	Identify interested parties including applicable laws, regulations, contracts etc.	Defined	Stakeholders identified (CEO, PM, Site Engineers, Clients, Admin)
4.2 (b)	Determine their information security-relevant requirements and obligations	Defined	Security requirements of stakeholders documented
4.3	ISMS scope		
4.3	Determine and document the ISMS scope	Defined	Scope clearly defined as ConstructFlow platform + supporting network (Option B)
4.4	ISMS		
4.4	Establish, implement, maintain and continually improve an ISMS according to the standard	Initial	ISMS is being designed as part of this assessment (not yet fully operating)
5	Leadership		
5.1	Leadership & commitment		
5.1	Top management must demonstrate leadership & commitment to the ISMS	Defined	CEO commitment is assumed and documented in recommendations
5.2	Policy		

Appendix E – Simplified RASCI Table

Section of ISO/IEC 27002:2013
R = Responsible A = Accountable S = Supportive C = Consulted I = Informed

Control ID	Control Description	CEO	Project Manager	Admin Officer	SME Engineer	Client
5	Information Security Policies	A	R	S	I	I
6.1	Information security roles & responsibilities	A	R	S	I	I
6.2	Mobile devices & teleworking	A	R	S	S	I
7.2.2	Security awareness & training	A	R	S	I	-
8.1	Asset management (Inventory & Ownership)	A	R	S	I	-
8.2	Information classification	A	R	S	I	I
9	Access Control (Policy, RBAC, MFA, Passwords)	A	R	S	I	I
9.2	User registration & access rights management	A	C	R	I	I
10	Cryptography (HTTPS, Encryption)	A	R	S	I	I
11.2	Protection from malware (Endpoint protection)	A	R	S	S	-
12.3	Information backup	A	R	S	I	-
12.4	Logging and monitoring	A	C	R	I	-
13.1	Network security & segregation	A	R	S	I	I
13.2	Information transfer (stop WhatsApp/email)	A	R	S	S	I
14.1	Security requirements of information systems	A	R	S	I	I
16	Information security incident management	A	R	S	S	I
17	Business continuity / Backup & recovery	A	R	S	I	-
Number of responsibilities		0	15	7	0	0
Number of accountabilities		17	0	0	0	0
Number of controls supported		0	0	15	4	0
Number of controls on which consulted		0	2	0	0	0
Number of controls of which informed		0	0	0	13	11

Google Drive –

https://docs.google.com/spreadsheets/d/1GBYiHNPkNk_j7p2c3a3_HNaIYPqMyKm/edit?usp=drive_link&ouid=105300668872313040311&rtmpof=true&sd=true

Appendix F – Glossary of Key Terms

Term	Definition
Access Control	The process of granting or denying specific users access to system resources based on their identity and assigned role.
Asset	Anything of value to the organization, including information, systems, hardware, software, and people.
Authentication	The process of verifying the identity of a user, device, or system (e.g., username + password, MFA).
Authorization	The process of determining what an authenticated user is allowed to do or access within the system.
Availability	Ensuring that authorized users can access information and systems when needed.
Baseline Network	The current or starting network environment of the organization before expansion or major changes (As-Is state).
CIA Triad	The three core principles of information security: Confidentiality, Integrity, and Availability.

Confidentiality	Ensuring that information is accessible only to those authorized to have access.
Prismo Constructions	The web-based project management platform being developed for Prismo Constructions to manage construction projects, progress, tasks, and client approvals.
Defense in Depth	A security strategy that uses multiple layers of controls so that if one control fails, others still provide protection.
Firewall	A network security device that monitors and controls incoming and outgoing traffic based on predetermined security rules.
Integrity	Ensuring that information remains accurate, complete, and unaltered except by authorized means.
ISO/IEC 27001	An international standard for establishing, implementing, maintaining, and continually improving an Information Security Management System (ISMS).
Least Privilege	The principle of giving users only the minimum access rights necessary to perform their job functions.
MFA (Multi-Factor Authentication)	An authentication method that requires two or more verification factors (e.g., password + OTP).
Network Segmentation	Dividing a network into smaller zones or segments to improve security and control traffic flow.
Option B	The assignment scenario selected for this project, focusing on a new or expanded network rather than improving an existing mature network.
RASCI	A responsibility matrix that defines roles as Responsible, Accountable, Supportive, Consulted, or Informed.
Residual Risk	The risk that remains after security controls and risk treatment measures have been applied.
Risk	The potential for loss or damage when a threat exploits a vulnerability.
Risk Assessment	The process of identifying, analyzing, and evaluating risks to determine their likelihood and impact.
Role-Based Access Control (RBAC)	An access control method that assigns permissions based on a user's role within the organization.
SoA (Statement of Applicability)	A document that lists the ISO 27001 Annex A controls that are applicable (or not applicable) to the organization and the justification for each.
Threat	A potential cause of an unwanted incident that may result in harm to a system or organization.

To-Be Architecture	The proposed future secure network design after implementing recommended security controls.
Trust Boundary	A logical boundary in a network where the level of trust changes (e.g., between internal network and the internet).
Vulnerability	A weakness in a system, process, or control that could be exploited by a threat.
Zone	A logical grouping of network resources with similar security requirements and trust levels (e.g., Office Zone, Server Zone, Remote Access Zone).